

REDES Y SEGURIDAD II



Seguridad en Redes

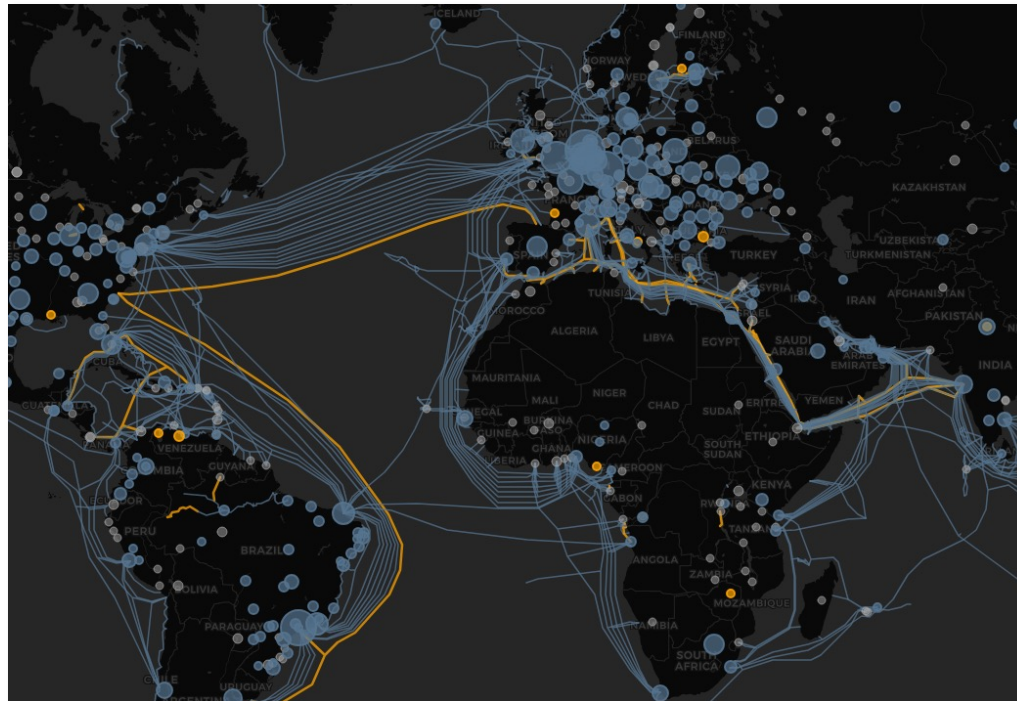
Modelo TCP/IP

- Protocolo de Control de Transmisión (TCP) + Protocolo de Internet (IP)
- Base de Internet
- Creado en 1972 por el departamento de defensa de Estados Unidos
 - Se inició implantación en ARPANET en 1983
 - Espina dorsal de Internet hasta 1990
 - Finalización de la transición
- Mantenido por IETF



Modelo TCP/IP

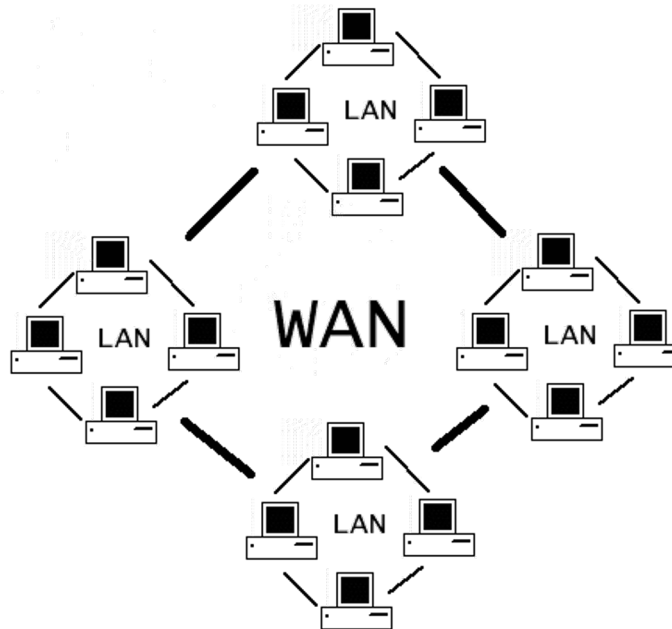
- Mapa lógico de Internet (hoy)



<https://map.kmcd.dev/>

Modelo TCP/IP

- **Objetivo:** enlazar máquinas de diferentes fabricantes y con distintos sistemas operativos
 - Sobre redes de área local (LAN)
 - Sobre redes de área extensa (WAN)





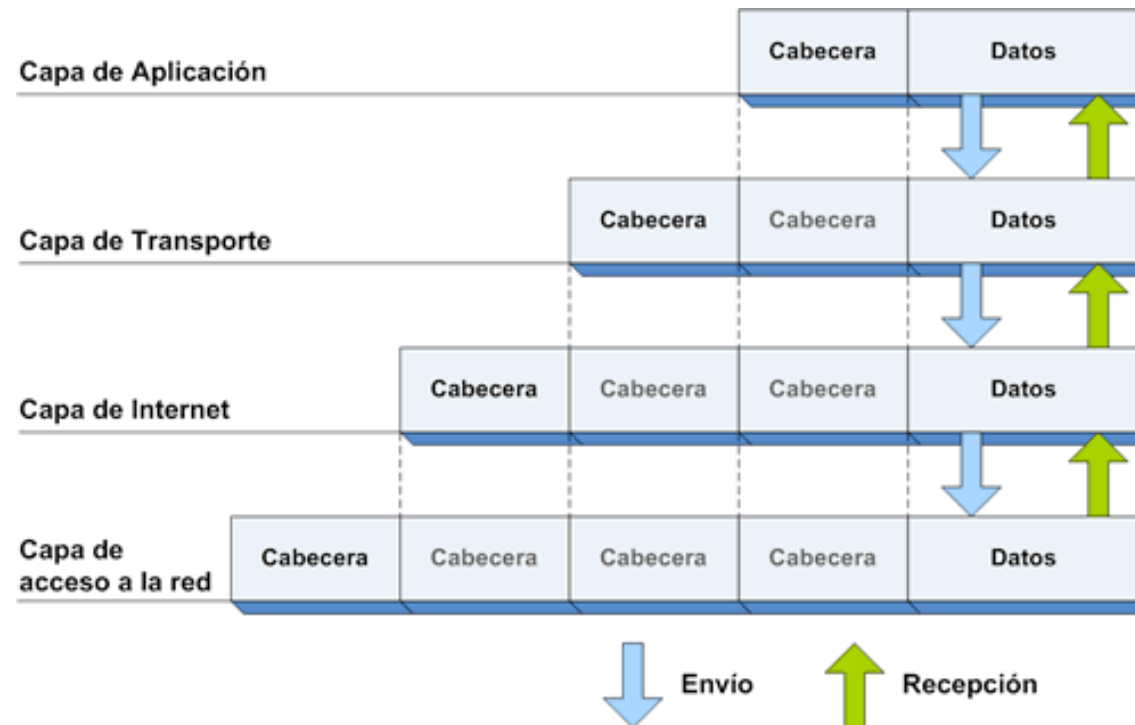
Modelo TCP/IP

- **Capas (RFC 1122):**
 - **Capa 1 (Enlace/Red):** Acceso al medio
 - Formada por equipos de una LAN o WAN homogénea
 - Todo lo que se encuentra debajo de la IP
 - **Capa 2 (Red/Internet):** Interconexión de equipos independiente de su tipo de conexión al medio
 - Funciones: dirección y encaminamiento
 - Implementada por todos los equipos conectados a Internet
 - **Capa 3 (Transporte):** Fiabilidad de la red
 - No implementada por routers
 - **Capa 4 (Aplicación):** aplicaciones que usan internet (clientes/servidores)
 - No implementada por routers



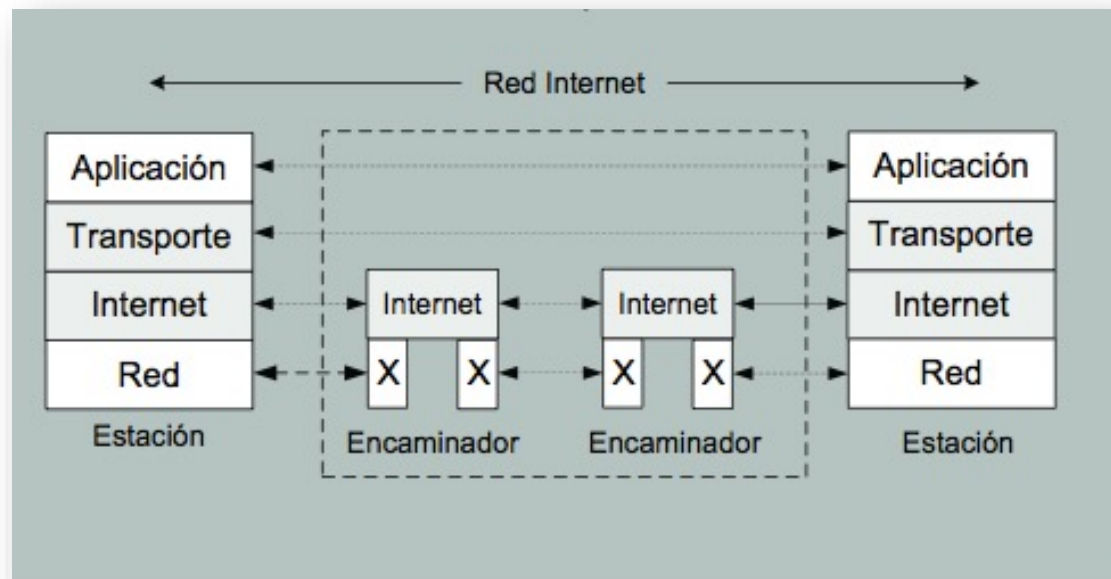
Modelo TCP/IP

- **Capas (RFC 1122):**



Modelo TCP/IP

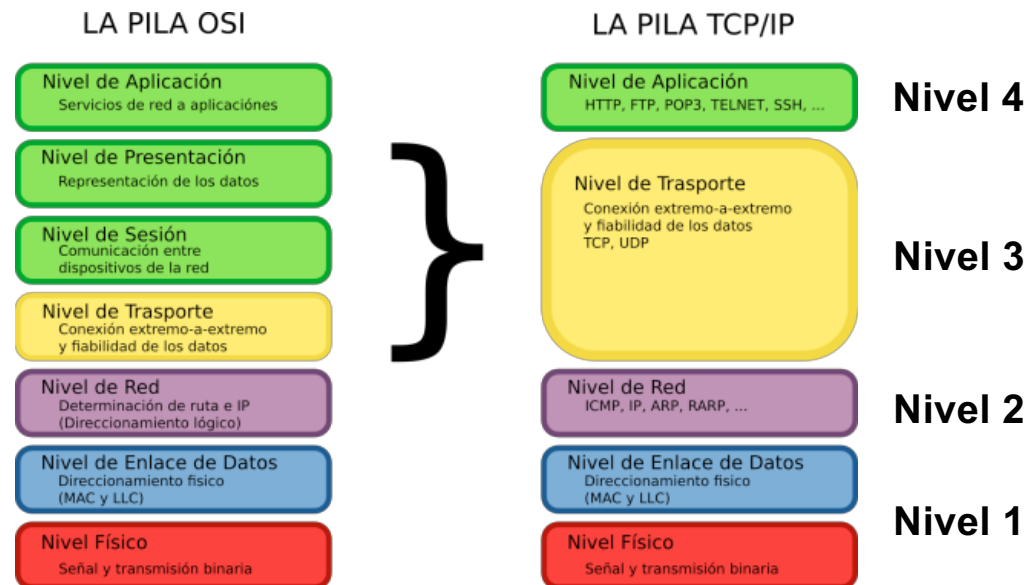
- **Capas (RFC 1122):**



Modelo TCP/IP



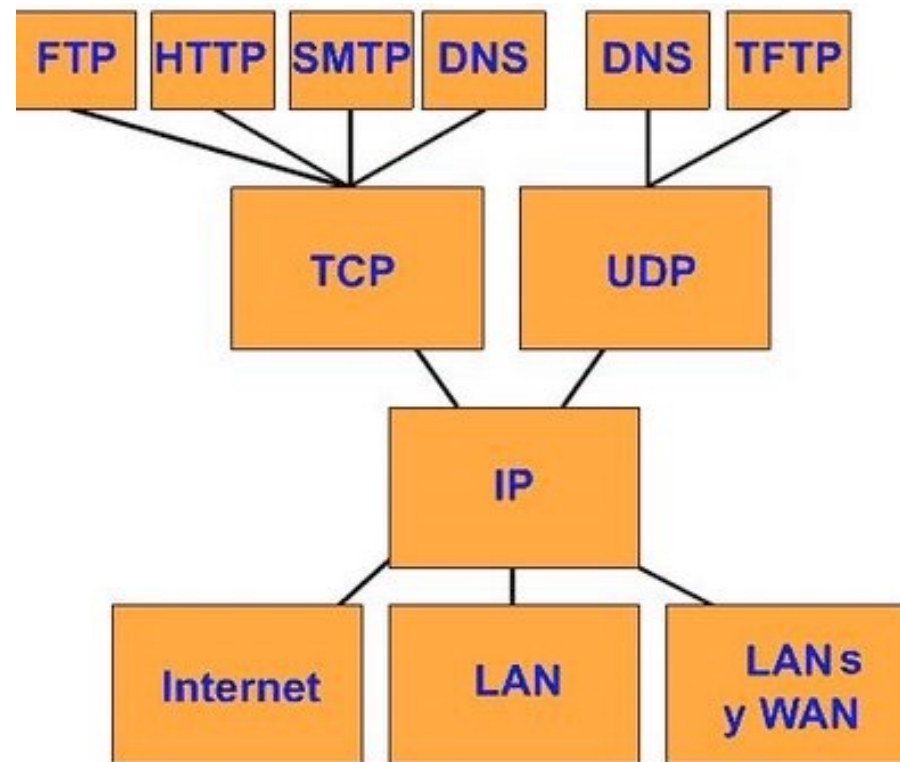
- **TCP/IP vs OSI**
 - **OSI:** Modelo de Interconexión de Sistemas Abiertos
 - Creado por ISO (1984)
 - Modelo teórico
 - **TCP/IP:** Una auténtica solución de ingeniería





Vulnerabilidades

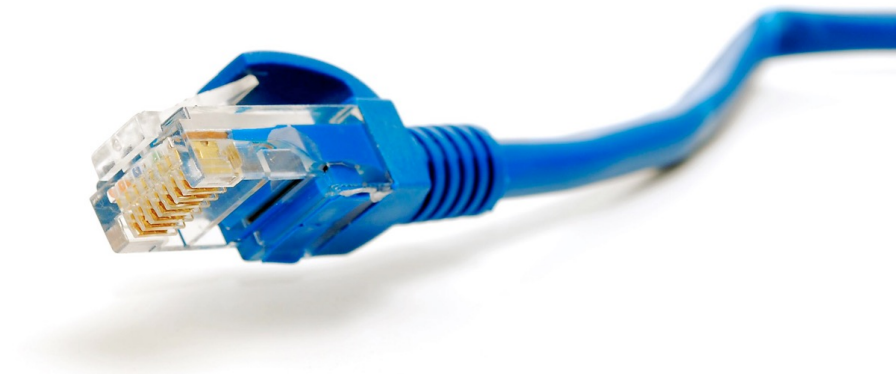
- Protocolos de cada nivel:



Vulnerabilidades

- **Capa 1 (Enlace/Red)**

- Ligadas al medio en el que se realiza la conexión
- Problemas de control de acceso y confidencialidad
- **Ataques:**
 - Redirección de cables de conexión a otros sistemas
 - Interceptación intrusiva de las comunicaciones
 - Interceptación no intrusiva de las comunicación (inalámbricas)



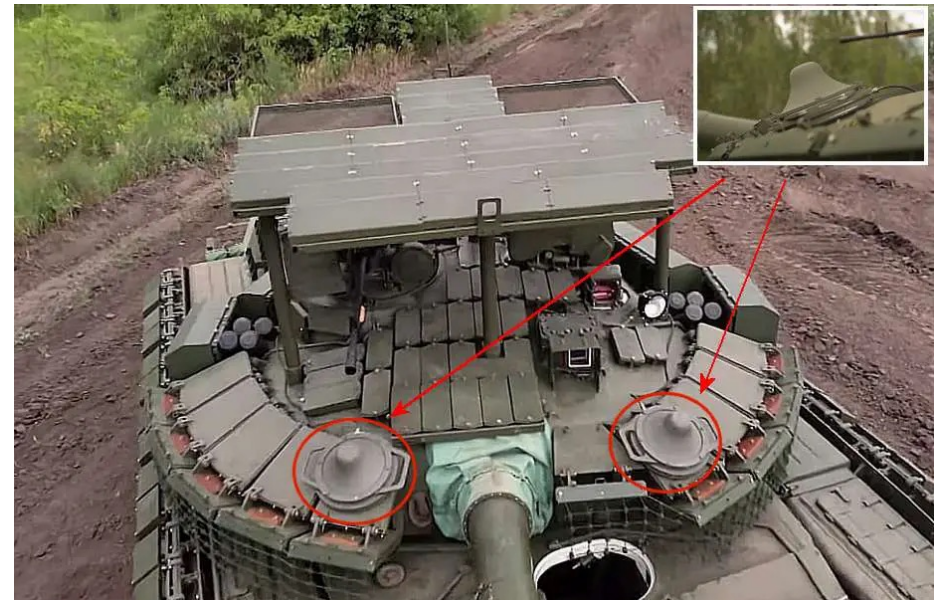
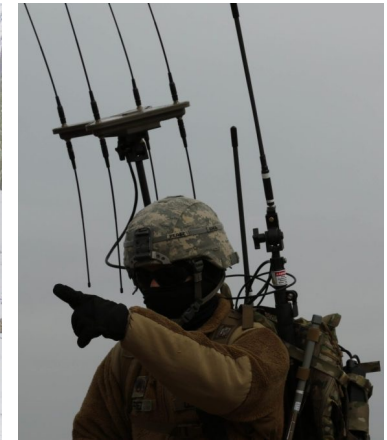
Vulnerabilidades

- **Capa 1 (Enlace/Red)**
 - Escuchas del CESID (ahora CNI) descubiertas en 1995
 - Objetivos usaban teléfonos móviles con protocolo ETACS
 - Variación del AMPS de Motorola
 - Analógico a 900 MHz
 - Ofertado por Moviline (Telefónica)



Vulnerabilidades

- **Capa 1 (Enlace/Red)**
 - Guerra de Ucrania (desde 2022)
 - Drones estándar y guerra electrónica
 - Inutilización de la plataforma
 - Localización de operador
 - Solución: cableado de fibra óptica
 - Hasta 20km de alcance recomendado



Vulnerabilidades

- **Capa 1 (Enlace/Red)**

- **ARP (RFC 826):** Protocolo de Resolución de direcciones

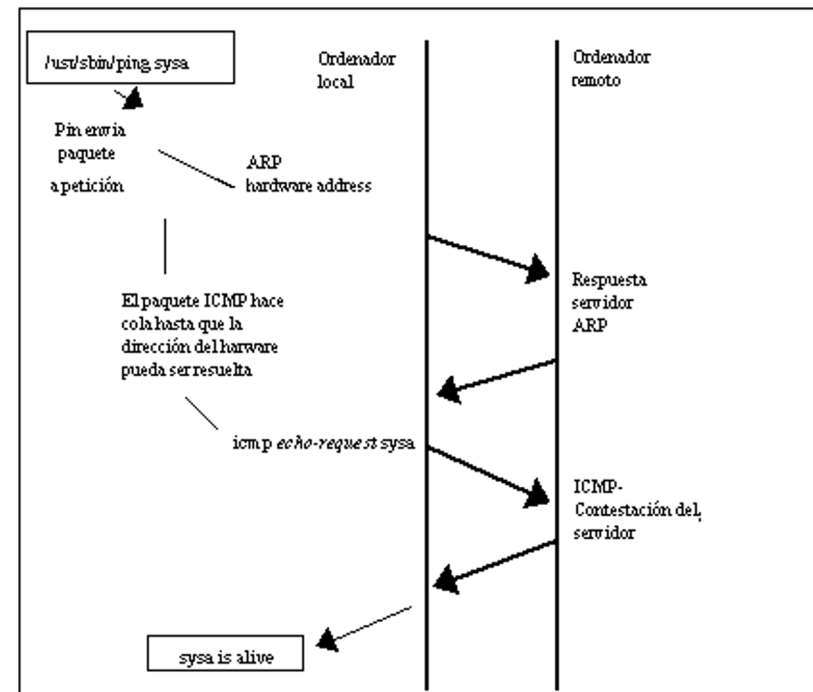
- Encuentra qué dirección física (MAC) corresponde a una dirección IP

- Correspondencia almacenada en tablas de cada máquina

- Entradas estáticas y dinámicas

- Funcionamiento:

1. Broadcast solicitando MAC de determinada IP
2. Respuesta del que tenga la correspondencia



Vulnerabilidades

- **Capa 1 (Enlace/Red)**

- **ARP (RFC 826):** Protocolo de Resolución de direcciones

- **Vulnerabilidad:**

- Se acepta la primera correspondencia recibida

- **Ataque:**

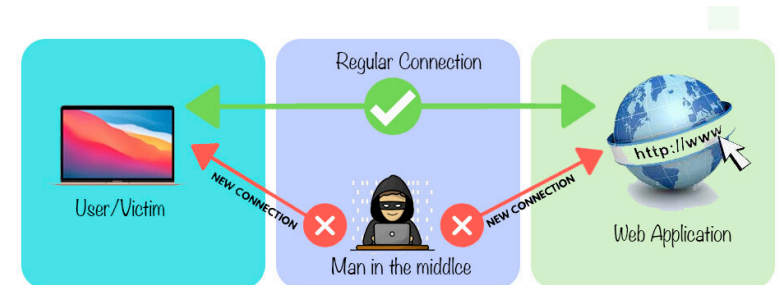
- **ARP Spoofing/Cache Poisoning**

- Suministrar entradas erróneas de la tabla ARP

- Suplantación de máquina legítima (***Man-in-the-middle***)
 - Denegación del servicio
 - Puede ser usado con fines legítimos (redundancia de servidores)

- **Defensa:**

- Tablas con entradas estáticas
 - Detección mediante el protocolo **RARP (ARP inverso)**
 - Si devuelve más de una IP es que hay ataque



Vulnerabilidades

- **Capa 2 (Red/Internet)**

- Vulnerable a cualquier ataque que afecte al datagrama IP
- Autenticación de paquetes se realiza a nivel de máquina (no usuario)

- **Ataques:**

- Captura (*sniffing*)
- Suplantación de mensajes
- Modificación de datos
- Retrasos/denegación de mensajes

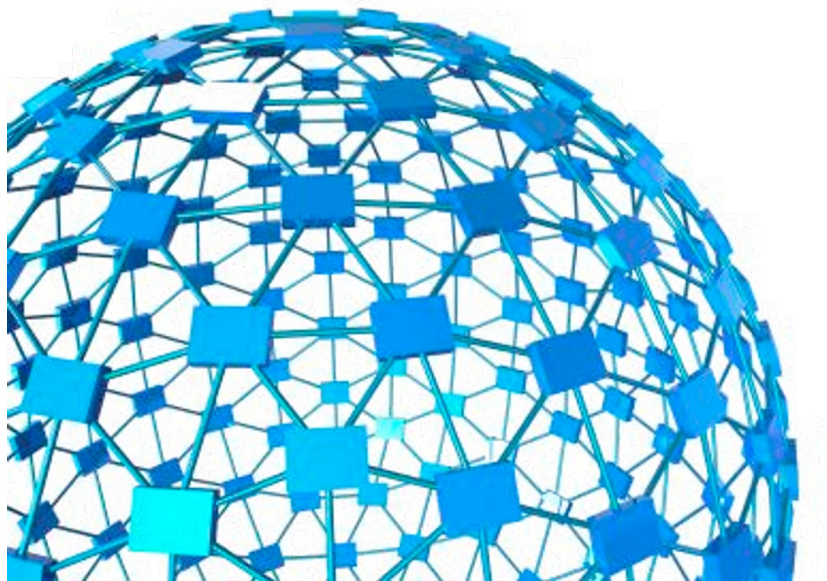


Vulnerabilidades

- **Capa 2 (Red/Internet)**

- **Protocolos:**

- **IP (Internet Protocol):** Transferencia de datagramas entre máquinas que pueden estar en redes distintas
 - **ICMP (Internet Control Message Protocol):** Mensajes de control de la red (respuesta a ping, destino inalcanzable, redirección, ...)



Vulnerabilidades

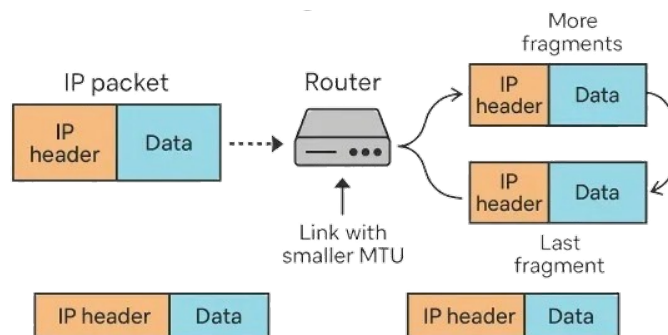
- **Capa 2 (Red/Internet)**

- **Fragmentación IP**

- Un datagrama se divide en varios cuando se supera la Unidad Máxima de Transferencia (MTU)
 - Fragmentos se ensamblan en destino

- **Ataques:**

- **Solapamiento:** un fragmento sobrescribe al anterior y viceversa
 - **Exceso de fragmentos y/o fragmentos incompletos:** llenado del buffer de ensamblado (denegación de servicio)
 - **Ensamblado excesivo:** la trama ensamblada supera los 64KB)
 - **Sobreescritura:** los últimos fragmentos sobrescriben datos de los anteriores con contenido dañino (sirve para saltarse defensas)



Vulnerabilidades

- **Capa 2 (Red/Internet)**

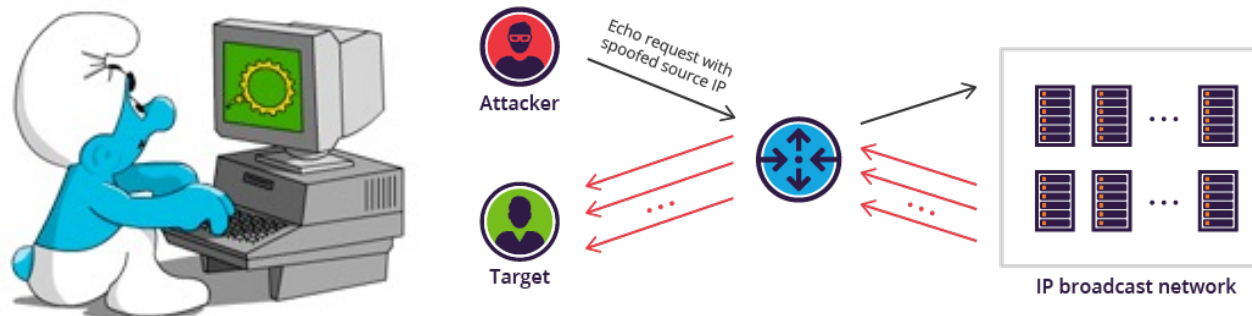
- **ICMP Echo Request/Echo Reply (ping/pong)**

- **Ataque ICMP Flood**

- Elevado número de peticiones *ping* de gran tamaño
 - Víctima debe responder colapsando su capacidad de proceso y ancho de banda
 - Imprescindible que la capacidad de proceso del atacante sea mayor

- **Ataque Smurf**

- Variante del anterior
 - Mensajes *ping* a broadcast usando IP de la víctima (**IP Spoofing**)
 - La efectividad aumenta con el número de máquinas en la misma red



Vulnerabilidades

- **Capa 3 (Transporte)**

- Vulnerable a cualquier ataque contra la autenticación, integridad y confidencialidad
- **Ataque:**
 - Denegación de servicio
 - Secuestro de la sesión



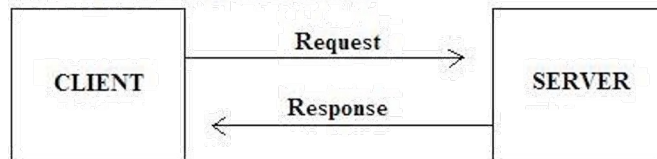
Vulnerabilidades

• Capa 3 (Transporte)

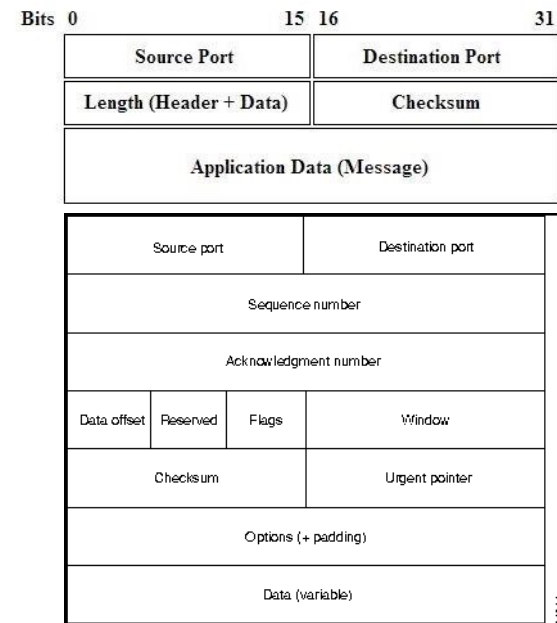
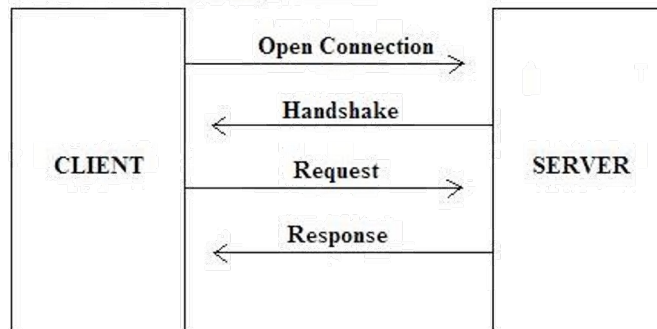
• Protocolos:

- **UDP:** transferencia de datos sin realizar conexión previa ni confirmación
- **TCP:** transferencia de datos con conexión previa y confirmación
 - Reenvío de datos corruptos

UDP Request / Response Paradigm



TCP Handshake Paradigm



Vulnerabilidades

- **Capa 3 (Transporte)**

- **Protocolo UDP:**

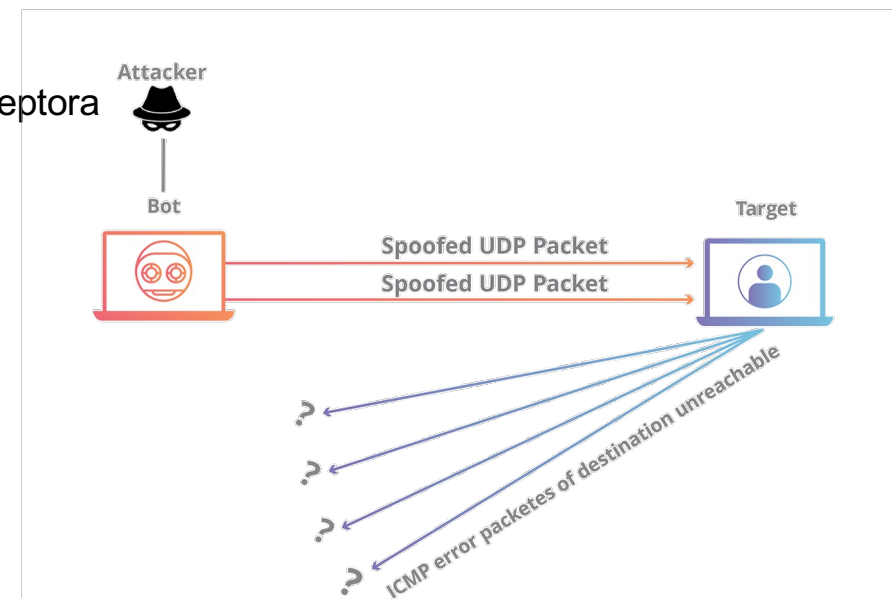
- **Vulnerabilidad:**

- Aceptación de paquetes sin conexión

- **Ataque:**

- **UDP Flood**

- Envío de grandes cantidades de paquetes a la víctima
 - Saturación de ancho de banda entre máquina emisora y receptora
 - Necesario **IP Spoofing**

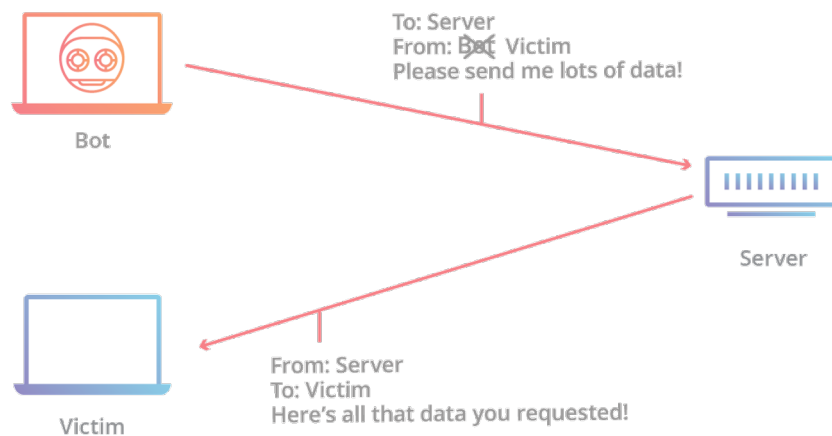


Vulnerabilidades

• Capa 3 (Transporte)

• Protocolo UDP:

- Ejemplo: DoS Counter-Strike 1.6 petición 'GameInfo'
- Envío masivo de solicitud 'GameInfo' a servidor falsificando origen
 - IP del cliente víctima
- Saturación del cliente víctima



SEARCH RESULTS Searching: Counter Strike 1.6 Servers

PREV 1 2 3 4 5 ... 1270 NEXT View 15 25 50 Items per page

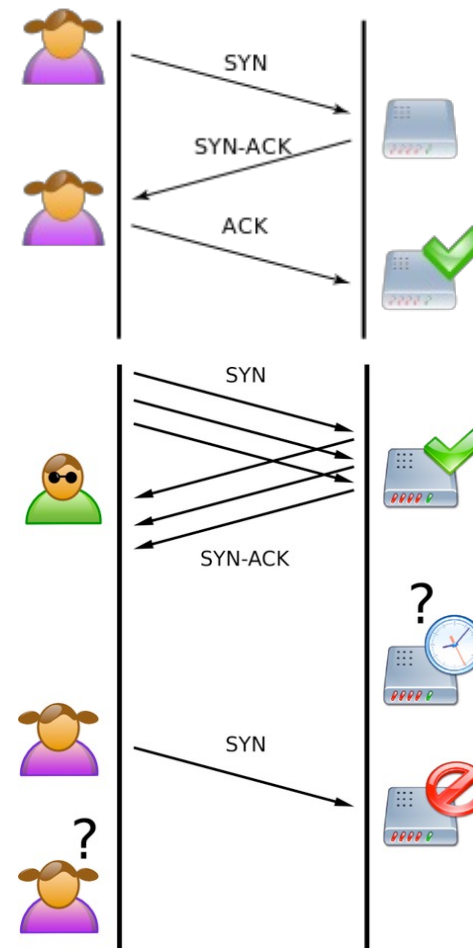
Rank	Gm	Server Name	Players	Loc	IP-Port	Server Map
1.		ZnOldSchool.CsBlackDevil.Com [Zombie Plague]	32/32		89.44.246.19:27015	zm_fox
2.		ИИЕНКММ 3ПМЛЕПТ @	32/32		77.220.182.200:27015	de_dust2
3.		Respawn.CsBlackDevil.Com [The Force of Darkness]	32/32		89.44.246.192:27015	de_dust2002
4.		ShadowZn.CsBlackDevil.Com [Zombie Plague]	32/32		89.44.246.127:27015	zm_deko2
5.		::MoNtEr_EnERgy@ISjeNICA™	32/32		176.57.128.40:27056	de_dust2
6.		Crazy Professionals - [PUB]	32/32		94.23.76.127:27015	de_dust2
7.		CS.MEKER.RO @ TOP15 AWARDS LICENTA STEAM	32/32		89.44.246.236:27015	de_dust2
8.		Sirmium Arena @ Assault Maps Only	32/32		176.57.142.99:27042	cs_assault_shadow
9.		[Caret-Plerepyproab] Public [Dust2]	32/32		91.210.107.27:27015	de_dust2
10.		CS.INDUNGL.RO # OFFICIAL INDUNGL SERVER	30/32		93.119.24.206:27015	de_nuke32
11.		::Pit Bull De_Dust2 Only:: @	31/32		193.192.59.74:27099	de_dust2
12.		+ 18 VIP-MOSCOW SERVER	31/32		193.26.217.101:27048	de_inferno
13.		This Server BY OMONAS !!! <cs,IT,It> www.omonas...	31/32		193.219.1.235:27015	de_inferno2se
14.		@ ORIGINAL QUNGAME	32/32		91.218.228.99:27015	de_dust_dust2
15.		[P1zzaServ] [Public] #1	32/32		77.220.180.177:27015	de_dust2_2x2

Rank Gm Server Name Players Loc IP-Port Server Map

PREV 1 2 3 4 5 ... 1270 NEXT View 15 25 50 Items per page

Vulnerabilidades

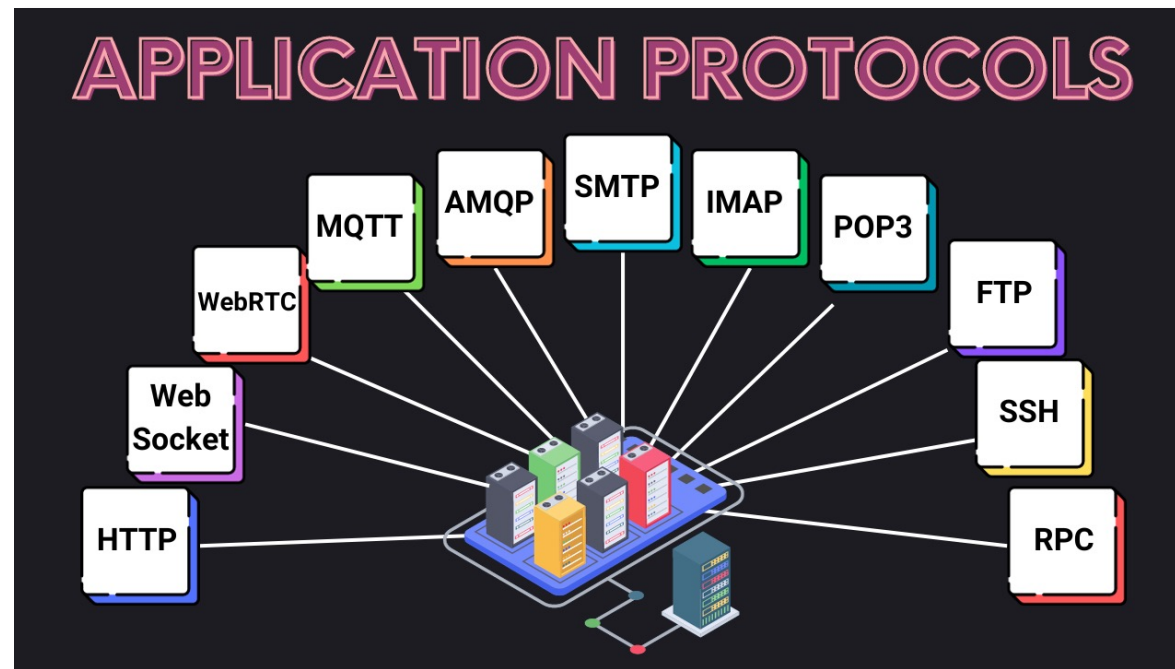
- **Capa 3 (Transporte)**
 - **Protocolo TCP:**
 - **Vulnerabilidad:**
 - Cada comunicación consta de 3 pasos que deben realizarse
 - **Ataque:**
 - **SYN Flood**
 - No devolver el ACK a la víctima
 - Aumenta el número de “conexiones semiabiertas”
 - Imprescindible **IP Spoofing**
 - **Defensa:**
 - Límite de conexiones por IP



Vulnerabilidades

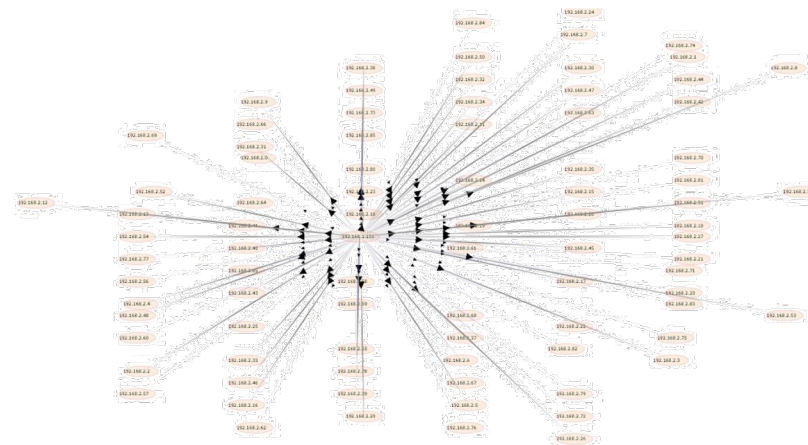
- **Capa 4 (Aplicación)**

- Variedad de protocolos pertenecientes a esta capa
- Vulnerabilidades que interrelacionan el resto de capas



Escaneo de Puertos

- Análisis de los puertos abiertos de una máquina conectada a la red
- Estado de un puerto
 - Abierto: hay un servicio escuchando
 - Cerrado: no hay ningún servicio escuchando
 - Detrás de un firewall: el servicio está protegido por un firewall
- Se puede detectar el sistema operativo en función de los puertos abiertos



Escaneo de Puertos

- **Nmap**
 - Estándar de facto
 - Creado por Fyodor Vaskovich (Gordon Lyon), 1997
 - Publicado en la Phrack Magazine con código fuente
 - **Características:**
 - Descubrimiento de hosts
 - Escaneo de puertos
 - Detección de versiones de los servicios
 - Detección del sistema operativo



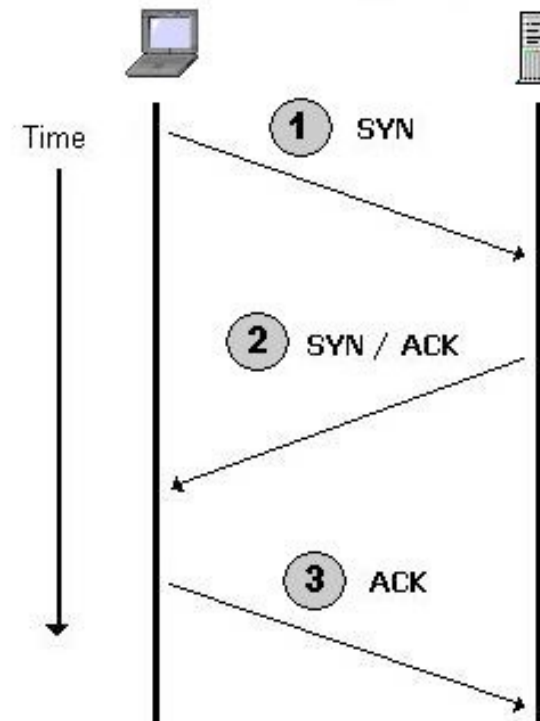
Escaneo de Puertos

- **Escaneo UDP**

- Envío de paquete UDP
- Abierto: Sin respuesta
- Cerrado: ICMP Port Unreachable
- Firewall: ICMP Port Unreachable

- **Escaneo TCP Connect**

- Establecimiento de conexión TCP completa
- Totalmente detectable



Escaneo de Puertos

- **Escaneo TCP SYN**

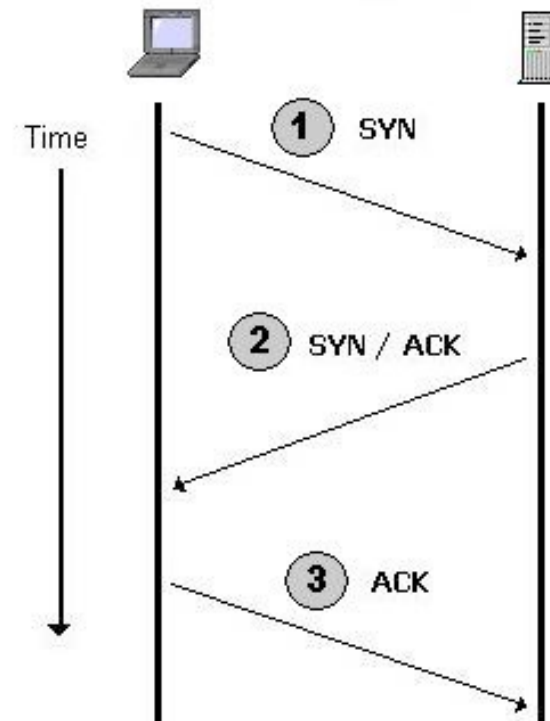
- Envío de paquete SYN
- Abierto: SYN/ACK
- Cerrado: RST
- Firewall: ICMP Port Unreachable

- **Escaneo TCP Xmas Tree**

- Paquete con (casi) todos los flags
 - FIN, URG y PUSH
- Cerrado: RST

- **Escaneo TCP Null**

- Paquete sin flags
- Cerrado: RST



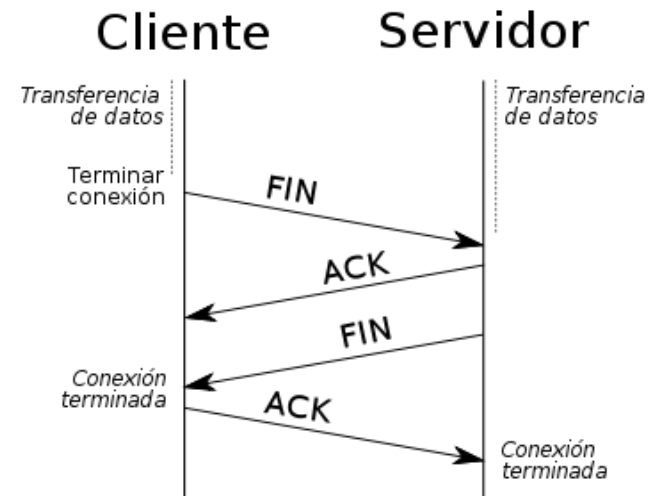
Escaneo de Puertos

- **Escaneo TCP FIN**

- Envío de paquete FIN
- Abierto: ACK
- Cerrado: RST
- Firewall: ICMP Port Unreachable

- **Escaneo TCP ACK**

- Envío de paquete ACK
- Determina si hay un firewall con estado
- Abierto y Cerrado: RST
- Firewall: distintos mensajes ICMP de error

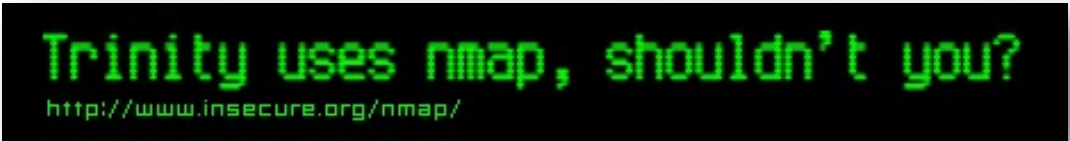




Escaneo de Puertos

- **Detección del sistema operativo**

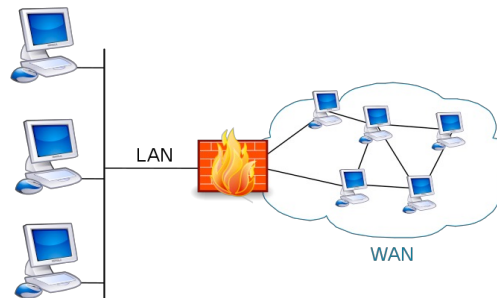
- Basado en la libre implantación de ciertos parámetros de TCP/IP
- Algunos campos TCP/IP a analizar:
 - Tamaño inicial del paquete (16 bits)
 - TTL inicial (8 bits)
 - Tamaño de ventana (16 bits)
 - Tamaño máximo de segmento (16 bits)
 - Flag "don't fragment" (1 bit)
 - Flag "sackOK" (1 bit)
 - Flag "nop" (1 bit)



Trinity uses nmap, shouldn't you?
<http://www.insecure.org/nmap/>

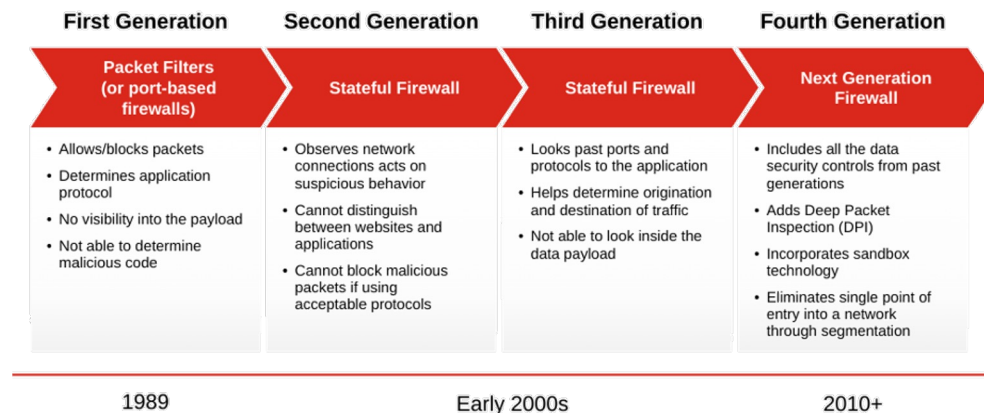
Firewalls

- Componente diseñado para bloquear el acceso no autorizado a través de la red
- **Motivación:**
 - No todas las aplicaciones y servicios están optimizados para la seguridad (no emplean autenticación y encriptación suficiente)
 - Las máquinas de la red pueden ser objeto de ataques con falsificación de la IP
 - Las máquinas de la red pueden ser objetivo de escaneo de puertos



Firewalls

- Antecedentes (Década de los '80)
 - Routers que mantenían separadas las redes (primer firewall)
 - Gusano Morris y siguientes amenazas cogieron por sorpresa a muchos administradores
- Generaciones:
 - **Primera (1988):** filtrado de paquetes
 - Digital Equipment Corporation y posteriormente AT&T Bell
 - **Segunda (1990):** inspección de estado (contexto) de paquetes
 - AT&T Bell
 - **Tercera (1991):** nivel de aplicación
 - Digital Equipment Corporation
 - **Cuarta/Nueva Generación (2004):** parte de 3ª Generación
 - Incluye elementos extra:
 - Inspección profunda de paquetes
 - Mecanismos propios de IDS/IPS





Firewalls

- **Tipos:**

- **Capa de red/filtro de paquetes**

- Examina cabeceras (direcciones IP, puertos) para permitir o bloquear el tráfico

- **Con inspección de estado**

- Toma decisiones en función del estado de las conexiones de red

- **Capa de aplicación**

- Nivel más alto de la pila TCP/IP
- Tipo especial: proxy (examina tráfico y actúa como intermediario en la conexión)

- **Gateway a nivel de circuito (Circuit-level Gateway)**

- Trabaja en el nivel (OSI) de sesión (verifica el handshake TCP/UDP)

- **Nueva Generación**

- Funcionalidad extra como control de aplicaciones e identificación de usuarios

TYPES OF FIREWALL



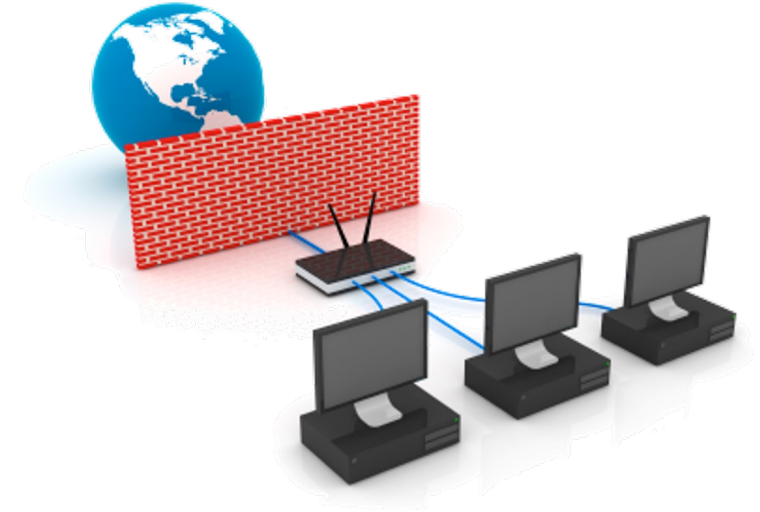
Firewalls

- **Capa de red/filtro de paquetes**

- El más sencillo (desde 1ª Generación) y más rápido
- Algunas métricas:
 - IP de origen: listas negras de servidores de correo
 - IP de destino: broadcasts hacia una determinada red
 - Protocolo del paquete: pings (ICMP) hacia una máquina

- **Tipos:**

- **Sin estado (1ª Generación):** no estudian el contexto del paquete
- **Con estado (>2ª Generación):** estudian el contexto del paquete y verifican si forma parte de un ataque
 - Procesado de origen (IP, puerto) y destino (IP, puerto)



Firewalls

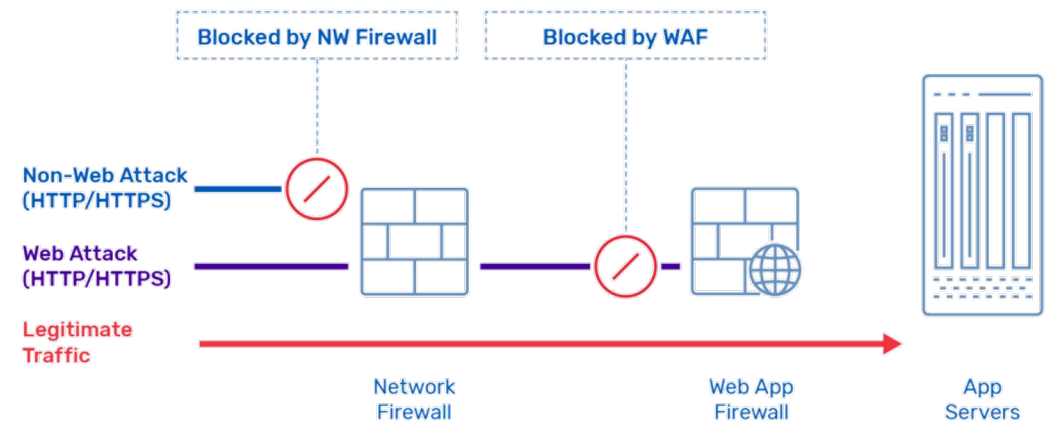
- **Capa de aplicación**

- Defensa contra gusanos, virus y troyanos
- No es un antivirus
- Más lento

- **Proxy:**

- Tipo especial de firewall de aplicación
- Responde a ciertas peticiones y bloquea el resto
- Diferentes protocolos
 - WAF: Web Application Firewall

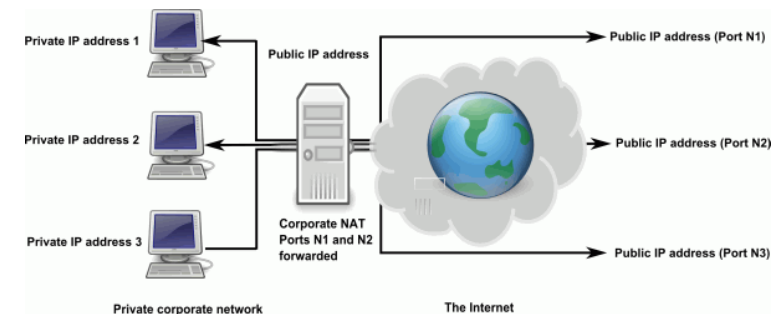
Web Application Firewall vs Network Firewall



Firewalls

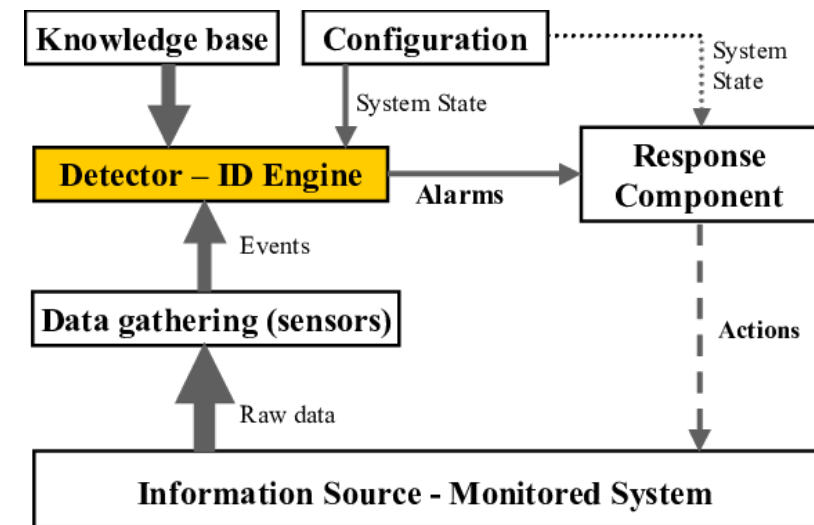
- **NAT (Network Address Translation)**

- RFC 2663
- Convierte en tiempo real las direcciones de los paquetes transportados de un extremo a otro del firewall
- Defensa contra descubrimiento de recursos por parte de atacantes
- **Modos:**
 - **Estático:** una IP pública se traduce a una IP privada
 - **Dinámica:** asignación dinámica de una IP pública para una IP privada en un momento determinado
 - **Sobrecarga:** petición a un puerto se traduce al puerto de una IP privada
 - Servicios repartidos entre diferentes máquinas de la red privada
 - Más usada: PAT (Port Address Translation)
- Se espera que IPv6 lo vuelva obsoleto



IDS

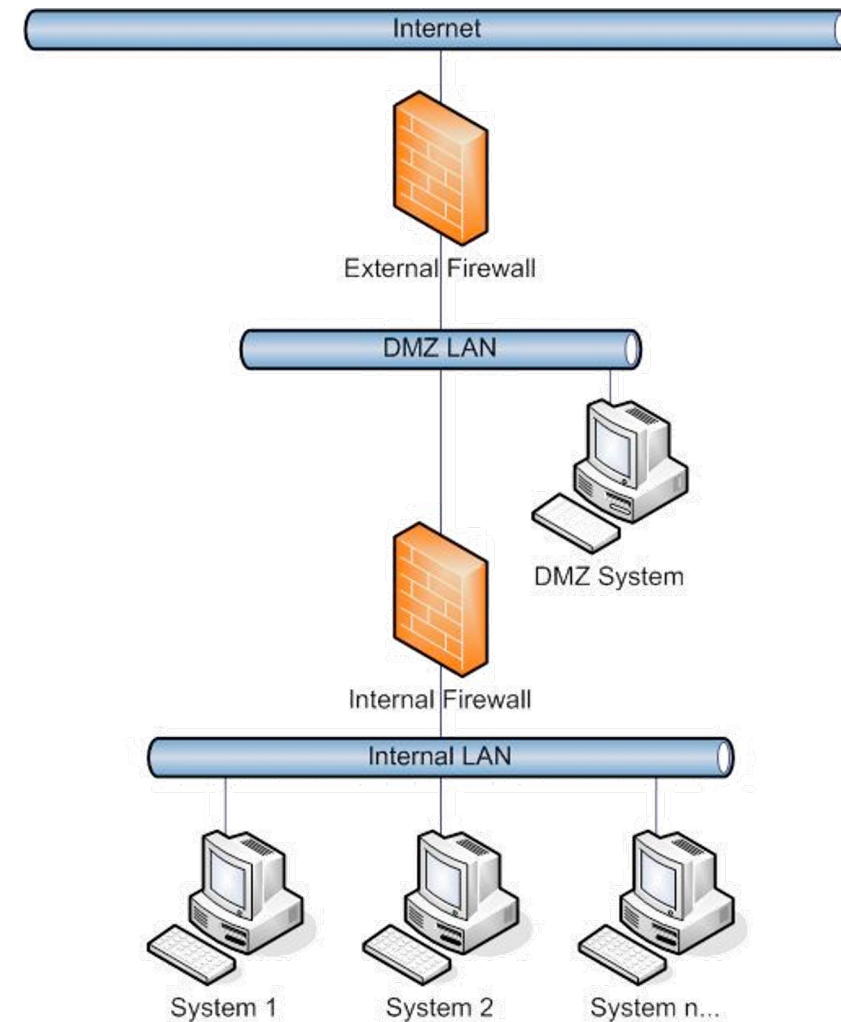
- Intrusion Detection System
- Primer prototipo por Dorothy E. Denning y Peter G. Neumann (1986)
- Monitorización de actividades no permitidas en sistemas y/o redes
 - A través de sensores (Ejemplo: *sniffers*)
 - Intentos de ataque y violación de políticas de seguridad
- Elaboración de informes de actividad
- Toma de decisiones reactivas (algunos)



IDS

- **Network IDS (NIDS)**

- Sistema independiente conectado a la red
- Examina el tráfico de la red
- Monitoriza múltiples máquinas
- Sensores ubicados en cuellos de botella (DMZ, extremos de la red)
- Análisis del contenido de los paquetes individualmente en busca de contenido malicioso
- Ejemplos: suricata, snort



IDS

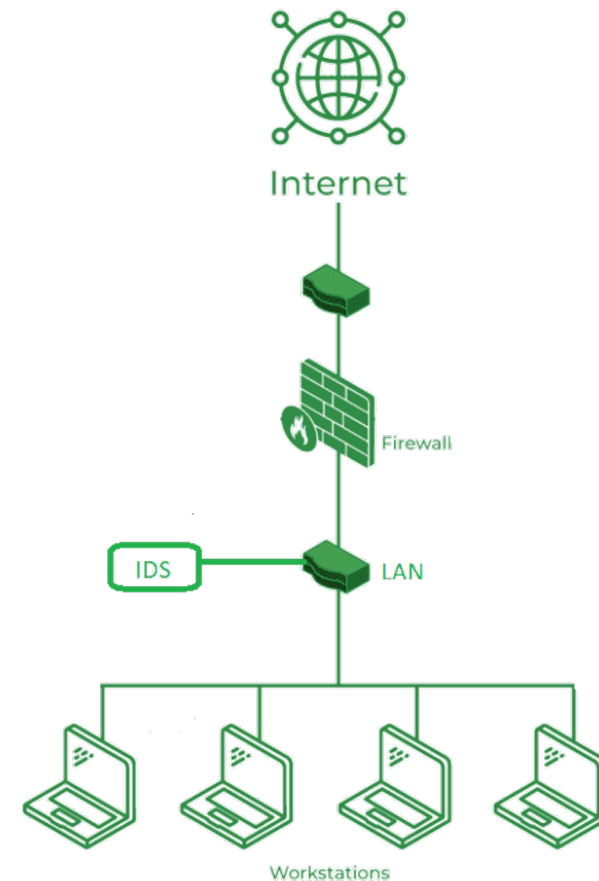
- **NIDS**

- **Ventajas**

- Una subred completa puede ser cubierta por un IDS
 - Teóricamente indetectables
 - Mínimo impacto a la red (según potencia de la máquina)
 - Permiten detectar ataques DoS
 - Independencia del ambiente operativo
 - Livianos y Fáciles de implementar

- **Desventajas**

- Generación de falsos positivos
 - No pueden analizar tráfico cifrado
 - Son tan efectivos como la última actualización de patrones
 - Alta latencia entre el ataque y la notificación
 - Dificultad para realizar análisis en redes congestionadas
 - No indican si un ataque ha sido exitoso o no



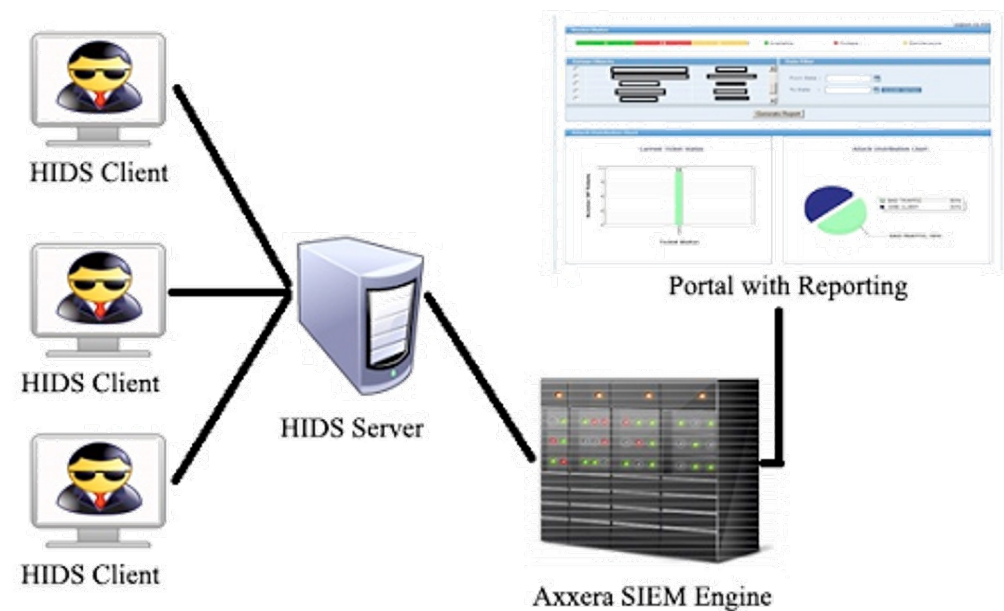
IDS

- **Host-based IDS (HIDS)**

- Agente en una máquina
- Analiza:
 - Llamadas del sistema
 - Registros de las aplicaciones
 - Modificaciones del sistema de ficheros
- Ejemplo: tripwire

- **Stack-based IDS (SBIDS)**

- Evolución de los HIDS
- Análisis de paquetes en todos los niveles de la pila TCP/IP



IDS

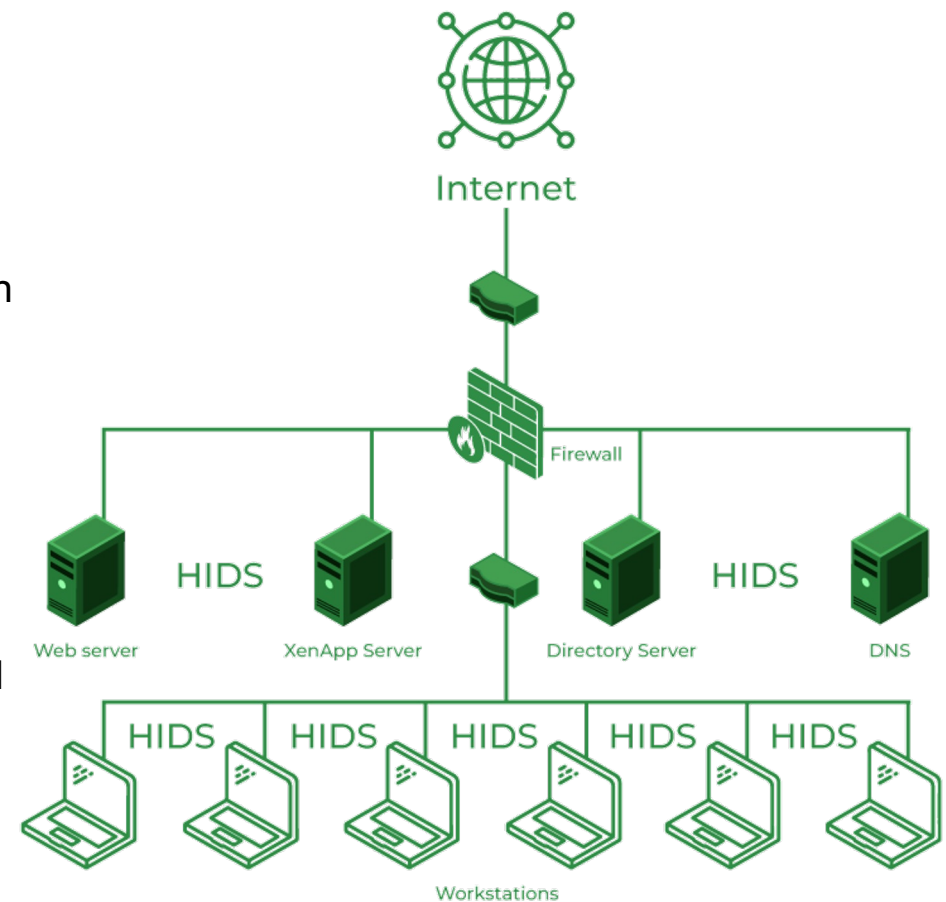
- **HIDS**

- **Ventajas**

- Permiten asociar usuarios y eventos
 - Pueden analizar tráfico cifrado
 - Pueden proveer información acerca de un ataque en una máquina durante el mismo ataque

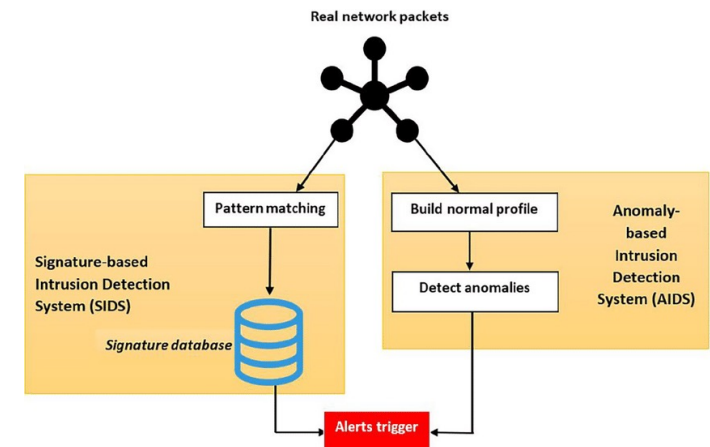
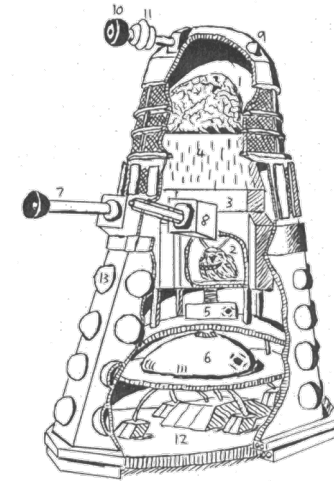
- **Desventajas**

- La información provista deja de ser confiable tan pronto como un ataque ha sido exitoso
 - Si la máquina sufre un ataque también el IDS se ve afectado
 - No son capaces de detectar descubrimientos de red
 - Requieren recursos de la máquina para trabajar



IDS

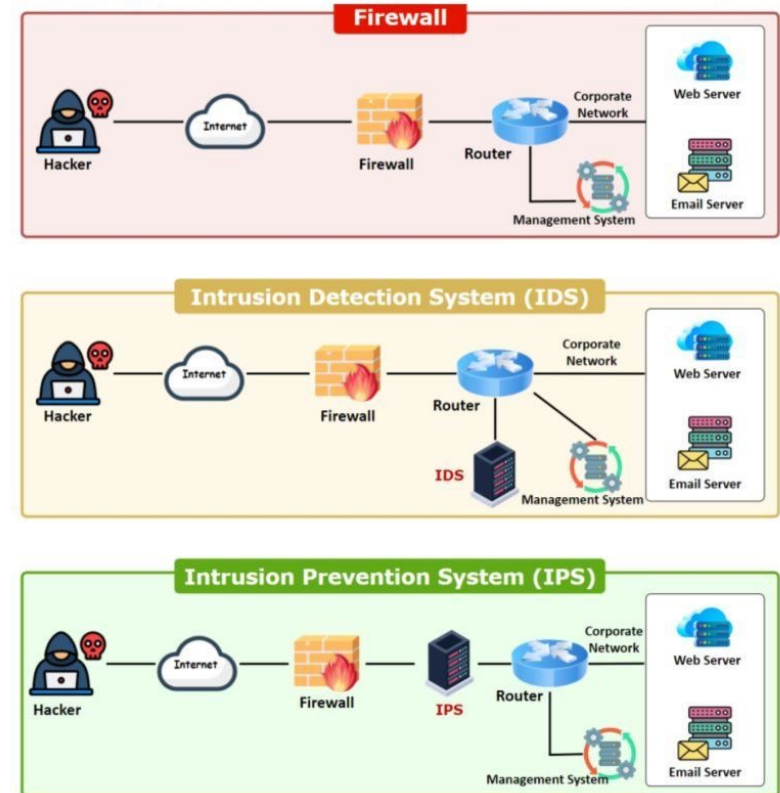
- **Sistema Pasivo**
 - Detección de ataques y notificación
- **Sistema Reactivo**
 - **Intrusion Prevention System (IPS)**
 - Detección de ataques, notificación y reacción
 - Filtrado de la conexión
 - Modificación de las reglas del firewall
- **Estadístico**
 - Detección de anomalías en función de un perfil realizado con antelación (protocolos, ancho de banda, ...)
- **Patrones**
 - Detección de patrones de ataques conocidos
 - Vulnerable a los ataques de “0 días”



IDS Vs. Firewall

- Firewall
 - Suele detectar amenazas frontales
 - Reglas basadas en un sensor
 - Acciones reducidas
- IDS
 - Detección de amenazas más complejas y en diferentes sentidos
 - Ataques por entunelamiento de tráfico
 - Ataques a través de vulnerabilidades en aplicaciones
 - Ataques que se originan desde la porción segura de la red
 - Reglas basadas en diversos sensores
- Algunos Firewall incluyen IDS
- Algunos IDS permiten añadir reglas de Firewall

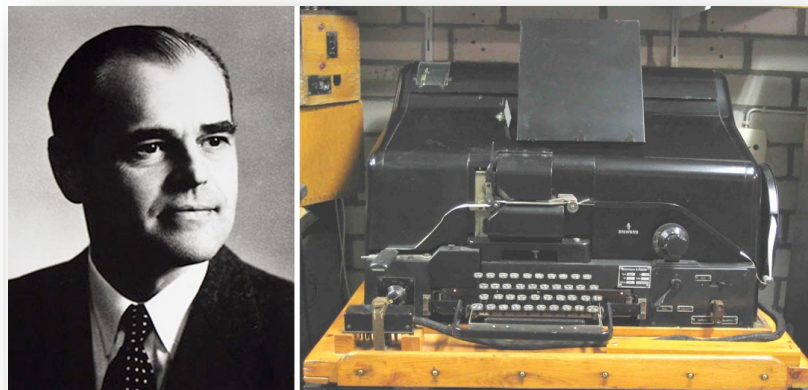
Firewall vs IDS vs IPS



Conexiones seguras

Máquina Lorenz (Alemania, Segunda Guerra Mundial)

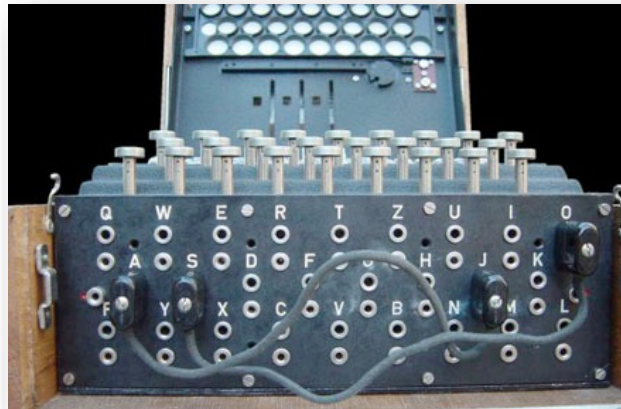
- Conectada a un teletipo (*teleprinter*) que a su vez estaba conectada a una línea de transmisión de datos (teléfono)
- Cada carácter se representaba con 5 bits (código Baudot) y después se cifraba
- Una de las versiones fue rota por el matemático sueco Arne Beurling



Conexiones seguras

Máquina Enigma (Alemania, Segunda Guerra Mundial)

- Dispositivo para operaciones de campo (diferentes versiones) sin conexión con línea de comunicaciones
- Cifrado iterativo (necesario conocer la posición inicial de los elementos)
- Rota por el matemático inglés y padre de la computación Alan Turing



Conexiones seguras

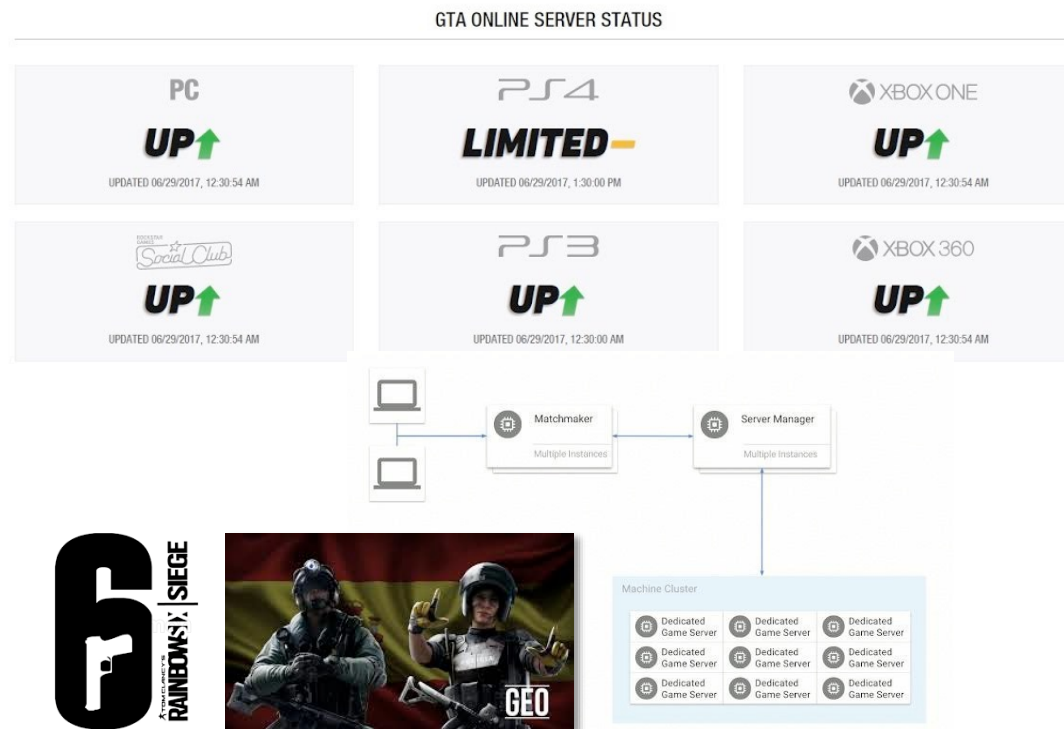
- **Secure Shell (SSH)**

- Creado por Tatu Ylönen (1995)
 - Reemplazar telnet, ftp y los comandos r* que eran inseguros
 - Versión comercial a través de SSH Communications Security
 - Versión gratuita para uso doméstico y académico
- Primer borrador a IETF (1997)
- Versión abierta: OpenSSH (1999)
- Segunda versión repara agujero de seguridad grave



Conexiones seguras

- **Secure Shell (SSH)**
 - ¿Cómo gestionar de forma segura los servicios desde cualquier lugar?



Conexiones seguras

- **Secure Shell (SSH)**

- Criptografía de clave pública (PKI) para autenticar tanto la máquina como el usuario
 - La clave pública se almacena en todas las máquinas a las que el usuario se autentica usando su clave privada
 - La clave privada nunca se transfiere
- Usos:
 - Acceso a máquinas remotas (reemplazando telnet y rlogin)
 - Ejecución de comandos remotos (reemplazando rsh)
 - Transferencia de ficheros segura (SCP y SFTP)
 - Transferencia de copias de seguridad y mirroring (con rsync)
 - Exportación del servidor X
 - Proxy Web cifrado (protocolo SOCKS)
 - Montaje seguro de sistemas de ficheros remotos (SSHFS)
 - Túnel SSH

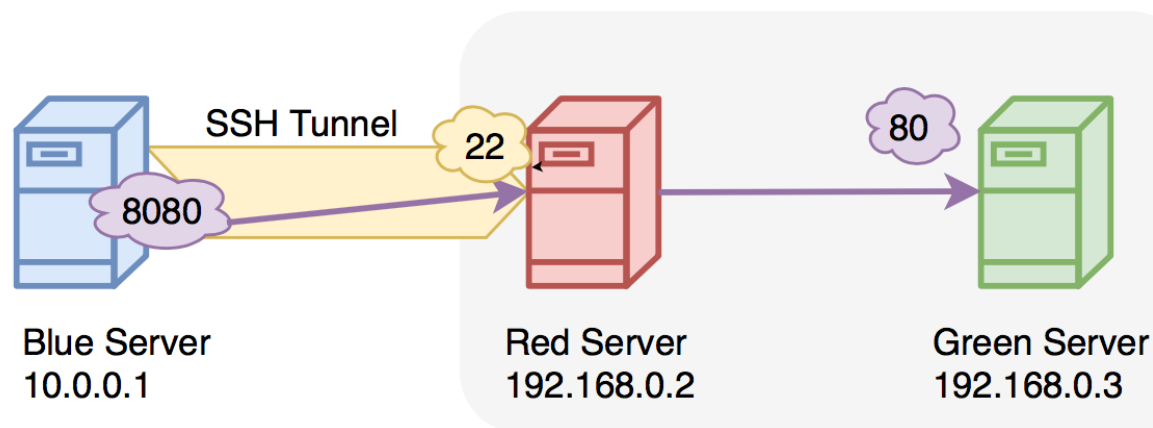


Conexiones seguras

- **Secure Shell (SSH)**

- **Túnel SSH**

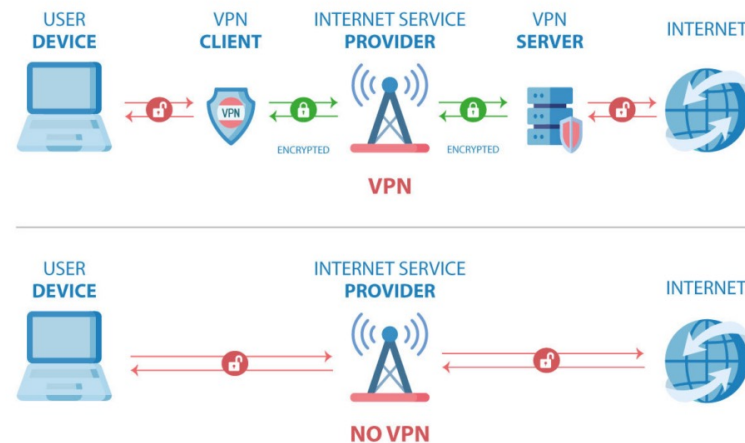
- Permite la comunicación de datos en un canal cifrado a través de una red
 - El cliente SSH enlaza un puerto local con un puerto de una máquina remota (pueden ser diferentes)
 - El protocolo SOCKS permite mayor flexibilidad de puertos
 - Se puede usar para saltarse el control impuesto por un firewall



Conexiones seguras

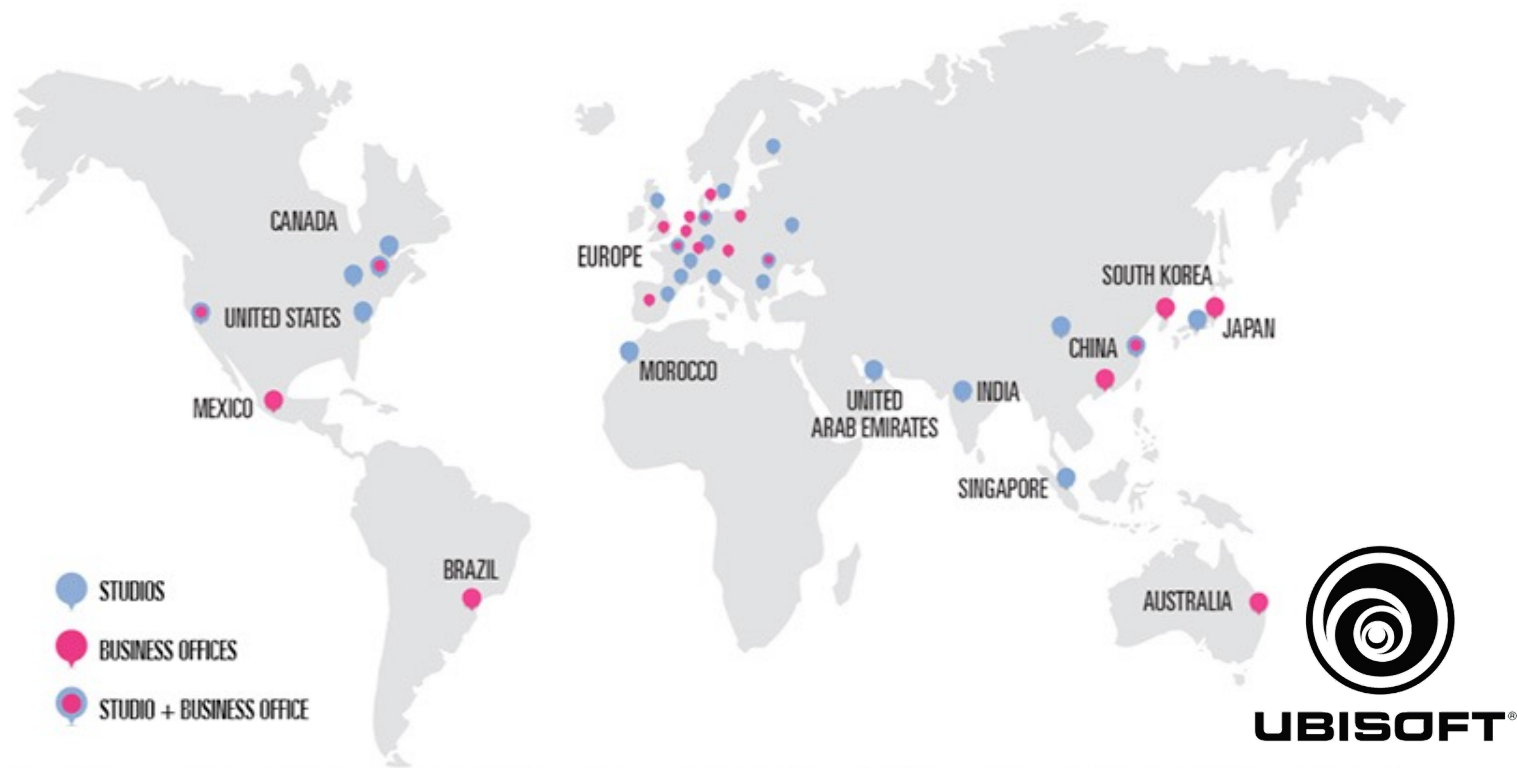
• Virtual Private Network (VPN)

- Surgió durante el primer funcionamiento de las redes dedicadas Frame Relay (WAN de conmutación de paquetes)
- Permite la extensión de una red local sobre una red pública
- Integridad, confidencialidad y seguridad de los datos
- Reducción de costes
- Facilidad de uso y comunicación entre puntos distribuidos



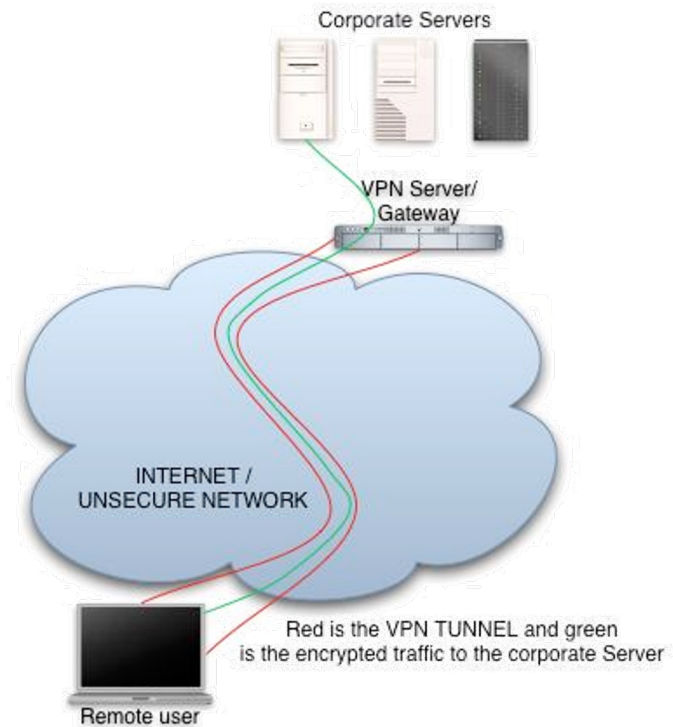
Conexiones seguras

- **Virtual Private Network (VPN)**
 - ¿Cómo extender de forma segura la red corporativa?



Conexiones seguras

- **Virtual Private Network (VPN)**
 - **VPN de acceso remoto**
 - usuarios se conectan a institución desde sitios remotos usando internet
 - Mismo nivel de acceso que máquina de red local
 - Reemplaza acceso dial-up y líneas dedicadas
 - Más usado actualmente

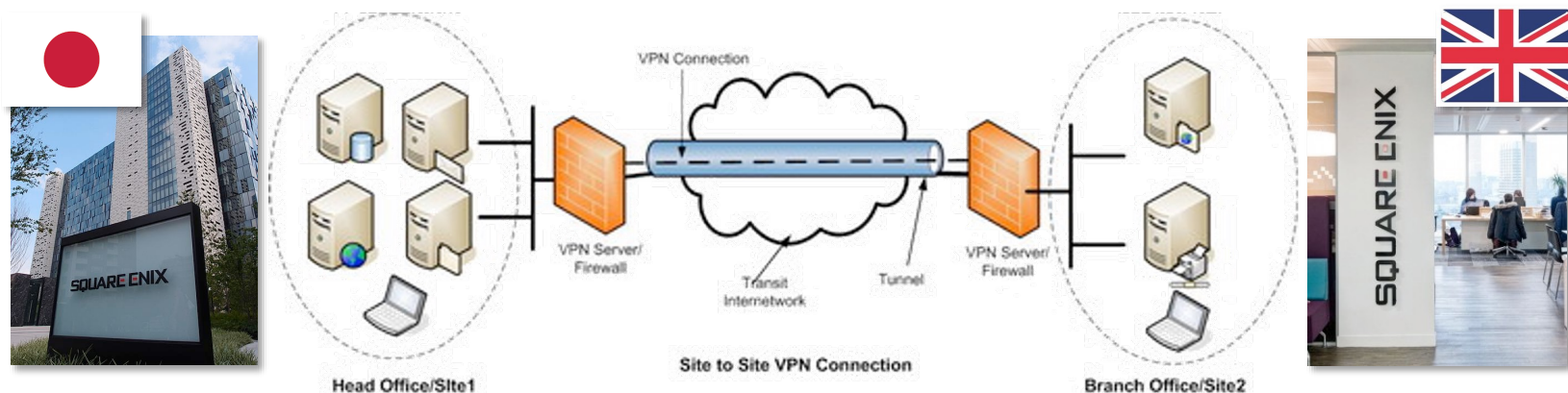


Conexiones seguras

- **Virtual Private Network (VPN)**

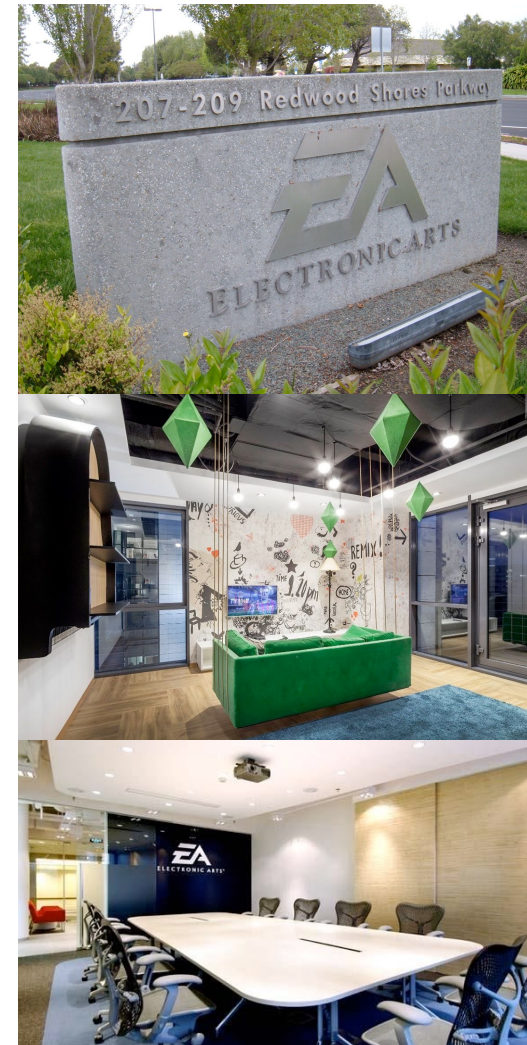
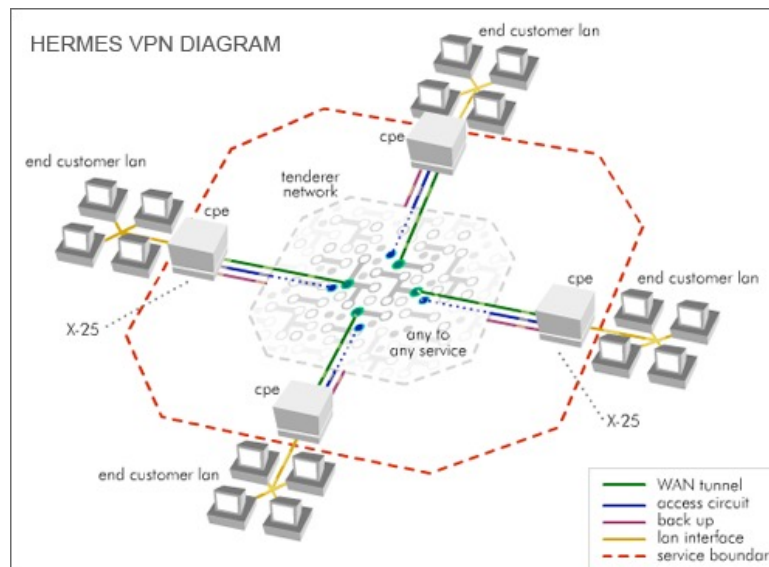
- **VPN punto a punto**

- Conexión de sucursales remotas con sede central
 - Servidor VPN en sede central acepta conexiones vía Internet y establece túnel
 - Suprime gastos en líneas dedicadas
 - Requiere de una conexión de banda ancha
 - Solución de seguridad especialmente cuando las sedes están repartidas internacionalmente



Conexiones seguras

- **Virtual Private Network (VPN)**
 - **VPN sobre LAN**
 - Aplicación dentro de la institución (LAN)
 - Aísla zonas y servicios de la red interna
 - Especialmente cuándo ésta tiene acceso Wifi
 - Menos difundido pero más poderoso





Conexiones seguras

- **Virtual Private Network (VPN)**

- **Protocolo IPSEC**

- Estándar de facto para VPN
 - Añade cifrado fuerte (entre otras cosas) al protocolo IP
 - Algoritmos de cifrado: DES, 3DES, IDEA y Blowfish
 - Algoritmos de hash: MD5 y SHA-1
 - Cifrado de Clave Pública: RSA
 - Certificados digitales

IPSec

IPsec vs. OpenVPN

IPsec

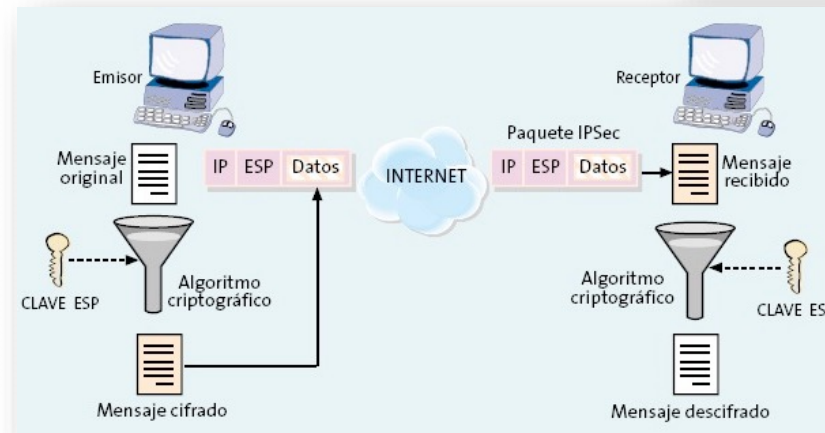
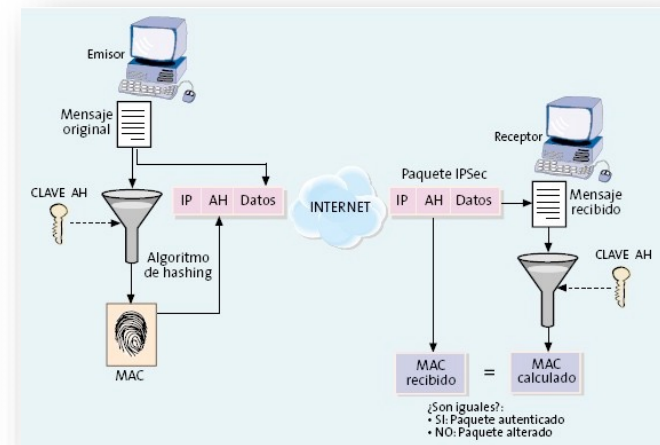
- Operates at the network layer
- Offers AH and ESP protocols
- Hardware accelerated; narrower cipher range
- Integrated into OS kernel; typically faster
- Native support in many OS and devices
- Complex setup due to extensive options
- Suited for fixed environments
- Standard for site-to-site VPNs

OpenVPN

- Operates at the transport layer
- Uses OpenSSL library
- Flexible cipher and key exchange options
- Double encryption; slightly slower
- Requires third-party software; strong cross-platform support
- Easy setup with a single configuration file
- Suited for dynamic or unpredictable environments
- Ideal for remote user access and navigating firewalls

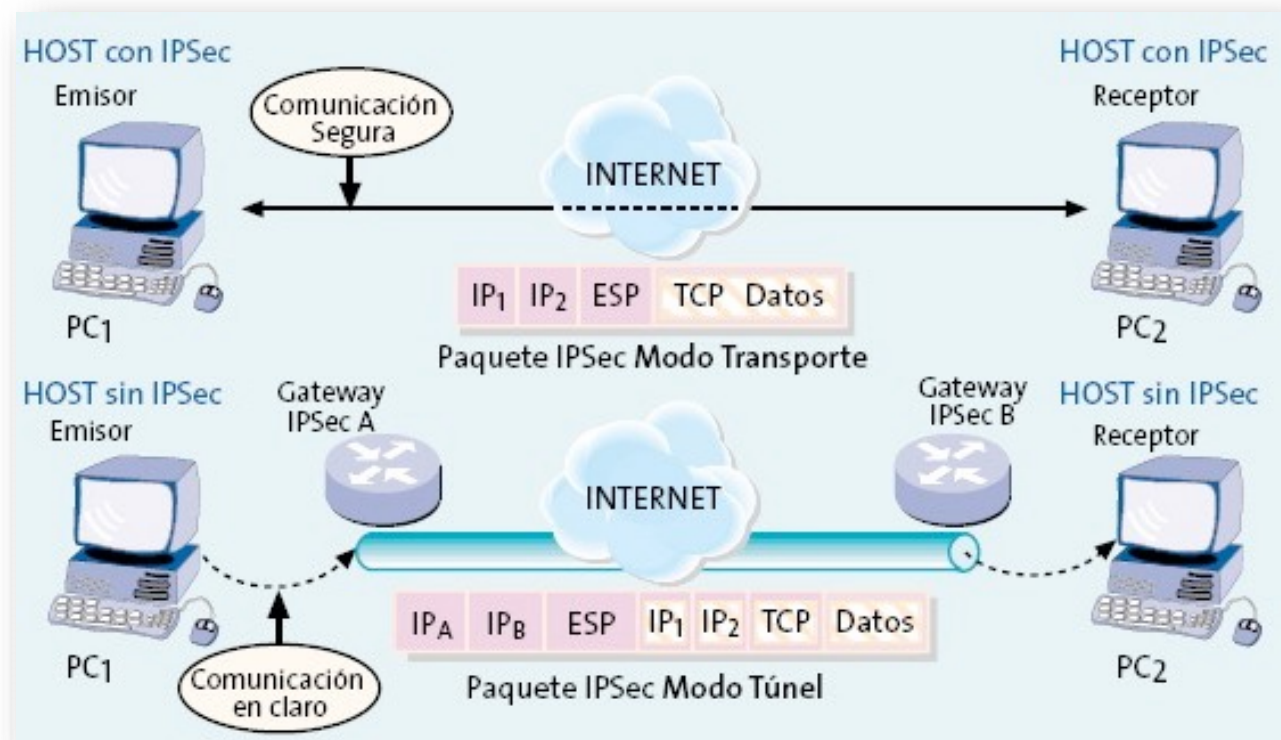
Conexiones seguras

- **Virtual Private Network (VPN)**
 - **Protocolo IPSEC**
 - Diseño modular
 - Componentes:
 - **Autenticación de cabecera IP (AH)**
 - **Carga de seguridad encapsulado (ESP)**
 - **Intercambio de claves de Internet (IKE)**



Conexiones seguras

- **Virtual Private Network (VPN)**
 - **Protocolo IPSEC**





Conexiones seguras

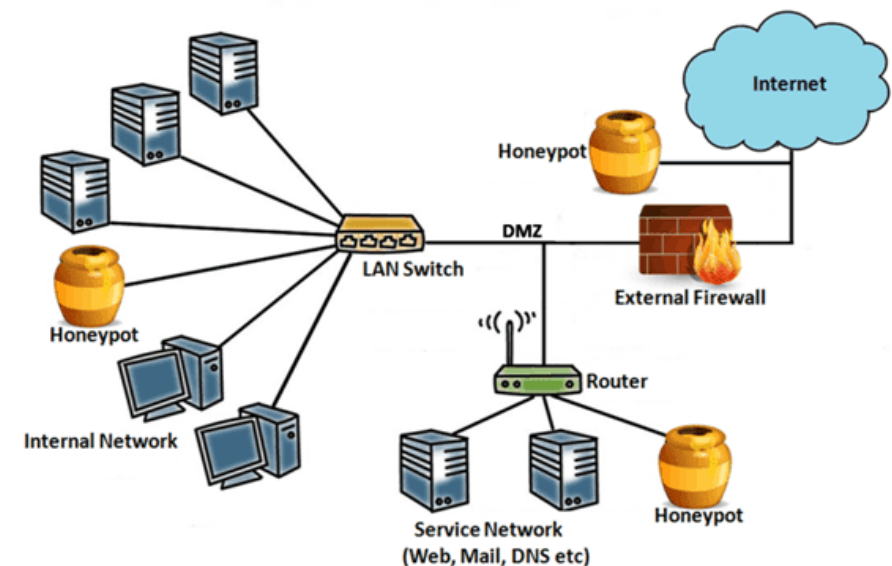
- **Virtual Private Network (VPN)**
 - Otros protocolos y comparativa

Protocolo	Velocidad	Estabilidad	Compatibilidad	Recomendado
WireGuard	Excelente ✓	Excelente ✓	Alto ✓	Usos más generales
OpenVPN	Bueno ✓	Muy bueno ✓	Alto ✓	Privacidad, redes restrictivas (con complementos)
IKEv2/IPsec	Muy bueno ✓	Excelente ✓	Alto ✓	Redes móviles
PPTP	Evitar ✗	Evitar ✗	Bajo ✗	Obsoleto
L2TP/IPsec	Evitar ✗	Evitar ✗	Bajo ✗	Obsoleto
SSTP	Evitar ✗	Evitar ✗	Bajo ✗	Obsoleto

Honeypots

- Software o conjunto de máquinas cuya misión es atraer a atacantes
- Simulan ser sistemas vulnerables
- Objetivos:
 - Estudiar las tendencias de ataque
 - Desviar la atención de los atacantes
 - Obtener información y pruebas contra los atacantes

*A un panal de rica miel
dos mil moscas acudieron
que por golosas murieron
presas de patas en él.*



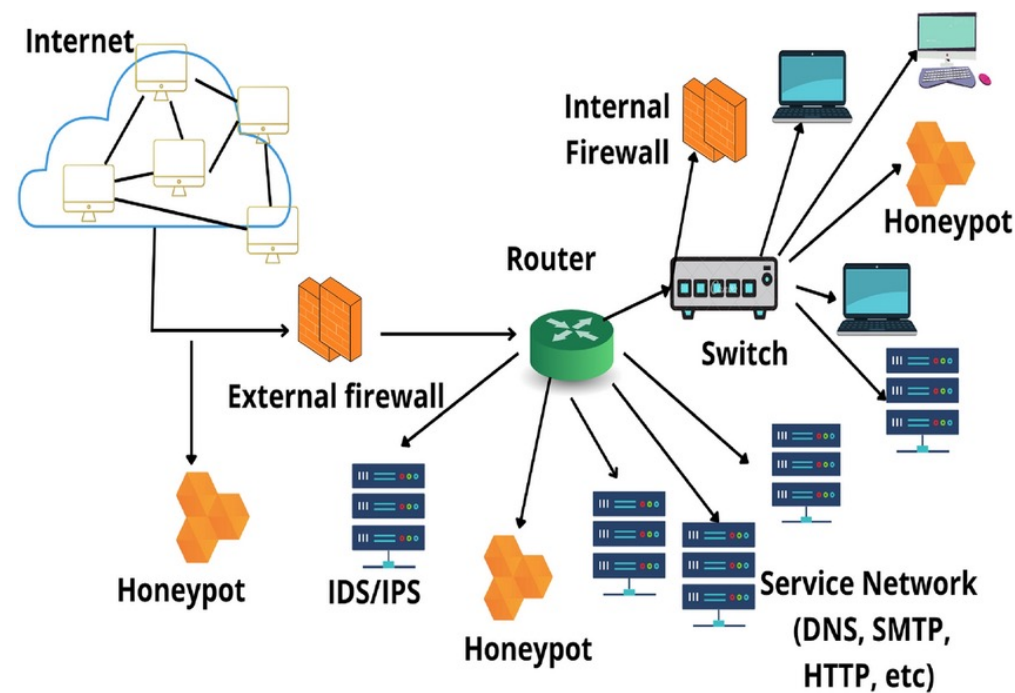
Honeypots

- **Producción**

- Fáciles de desplegar y mantener
- Capturan información mínima

- **Investigación**

- Complejos y difíciles de desplegar y mantener
- Capturan muchísima información



Honeypots

- **Puro**

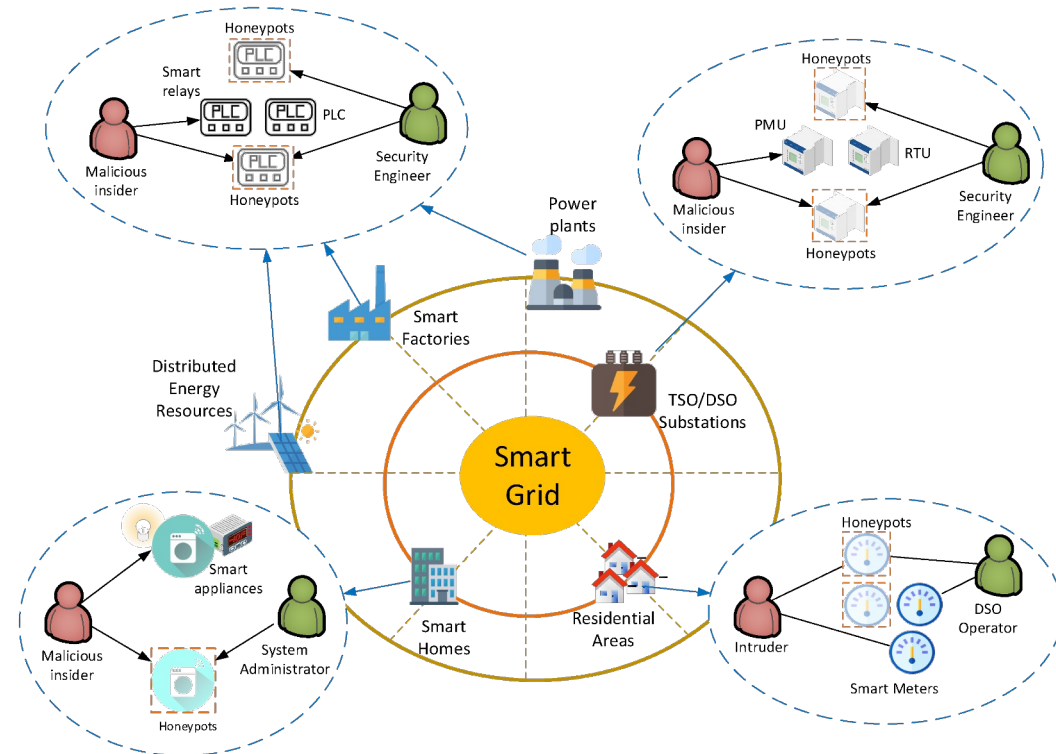
- Sistema de producción completo como cebo
- Monitorización en el enlace con la red

- **Alta Interacción**

- Gran cantidad de servicios instalados
- Monitorización pasa más desapercibida
- Sistemas de Investigación

- **Baja Interacción**

- Escasos servicios instalados (los más comúnmente atacados)
- Sistemas de producción



Honeypots

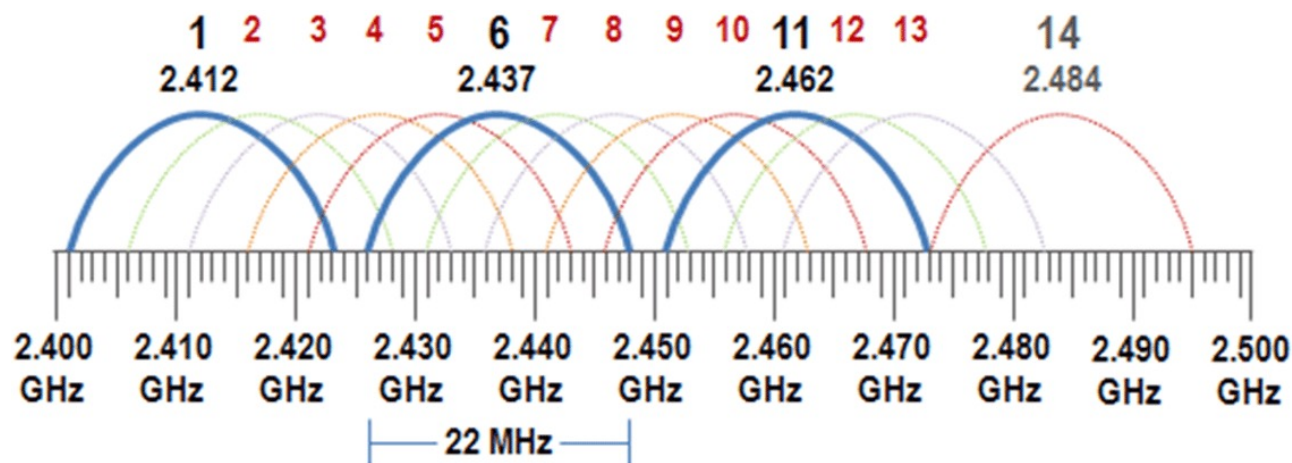
- **Honeynet**
 - Conjunto de honeypots de alta interacción
 - Actúan sobre toda la red
 - Honeynet Project (1999)
 - Concepto de Lance Spitzner (Fundador)
 - Fyodor (Fundador)





Wi-Fi

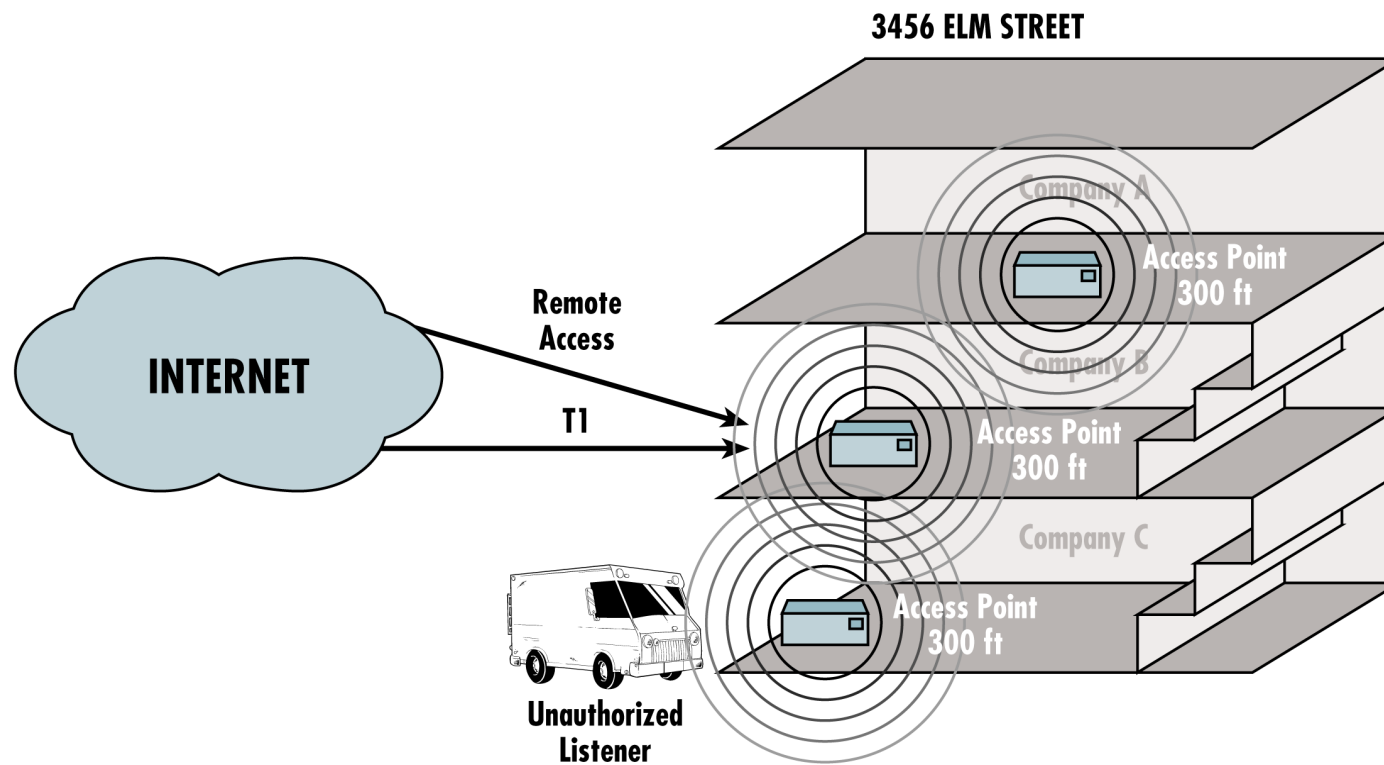
- Tecnología con la movilidad como primer objetivo
- Evolución de otras tecnologías (Ej: ALOHA)



IEEE Standard	WiFi Gen	Year	Frequency	Max PHY Data Rate	Max Range
802.11	-	1997	2.4 GHz	2 Mbps	20m (indoor) 100m (outdoor)
802.11 a	-	1999	5 GHz	54 Mbps	35m (indoor) 120m (outdoor)
802.11 b	-	1999	2.4 GHz	11 Mbps	35m (indoor) 140m (outdoor)
802.11 g	-	2003	2.4 GHz	54 Mbps	38m (indoor) 140m (outdoor)
802.11 n	WiFi 4	2009	2.4/5 GHz	600 Mbps	70m (indoor) 250m (outdoor)
802.11 ac	WiFi 5	2013	5 GHz	6.9 Gbps	35m (indoor)
802.11 ad	-	2012	60 GHz	8.1 Mbps	3.3m (indoor)
802.11 ah	-	2017	Sub 1 GHz	347 Mbps	1km
802.11 ax	WiFi 6	2021	2.4/5/6 GHz	9.6 Gbps	30m (indoor) 120m (outdoor)
802.11 ay	-	2021	60 GHz	303 Gbps	10m (indoor) 100m (outdoor)
802.11 be	WiFi 7	2024	2.4/5/6 GHz	46.1 Gbps	30m (indoor) 120m (outdoor)

Wi-Fi

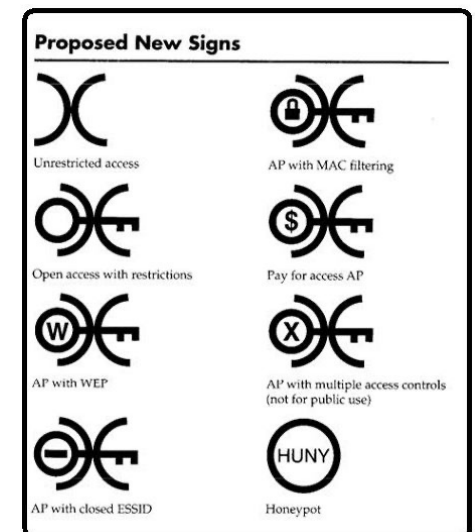
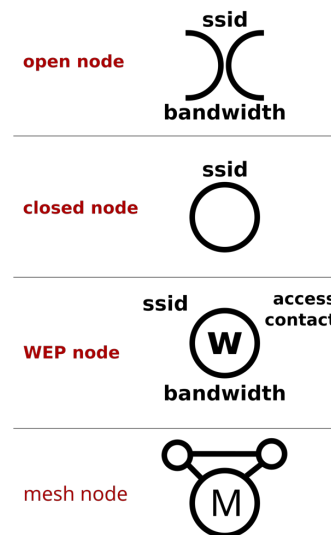
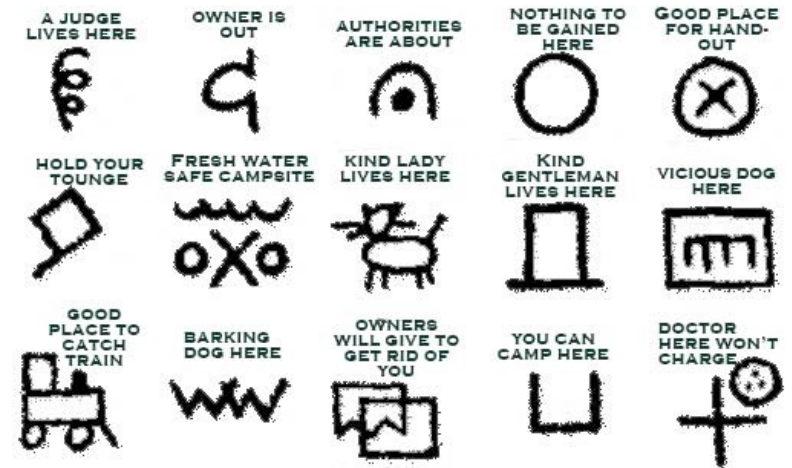
- Su principal objetivo es su principal punto débil



Wi-Fi

• Warchalking

- Dibujar en paredes o aceras una serie de símbolos para indicar a otros la proximidad de un acceso inalámbrico
- Antecedentes durante la Gran Depresión de 1929 en Estados Unidos (*Hobo Code*)
 - Los vagabundos dibujaban símbolos en los edificios para marcar los lugares donde podían conseguir comida
- Reflotado en el 2000 para indicar hotspots

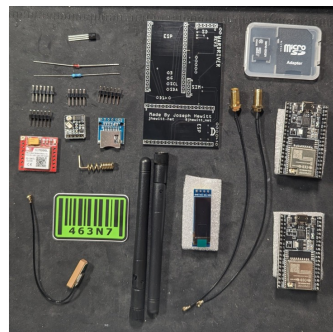


Wi-Fi

- **Wardriving**

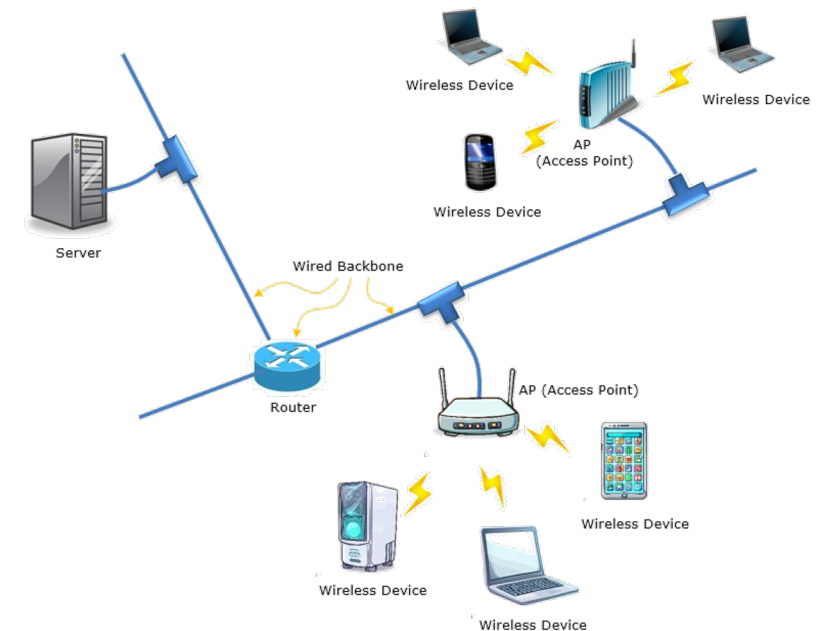
- Localización de puntos de acceso wireless en un área geográfica extensa
- Equipo:
 - Portátil u otro dispositivo móvil con tarjeta inalámbrica y unidad GPS
 - Antena de gran ganancia (Comprada o casera tipo “lata de Pringles” o “tubo PVC”)
 - Software de monitorización Wifi

 Location accuracy is low
This might be due to weak GPS or Wi-Fi signals
[Learn more](#)



Wi-Fi

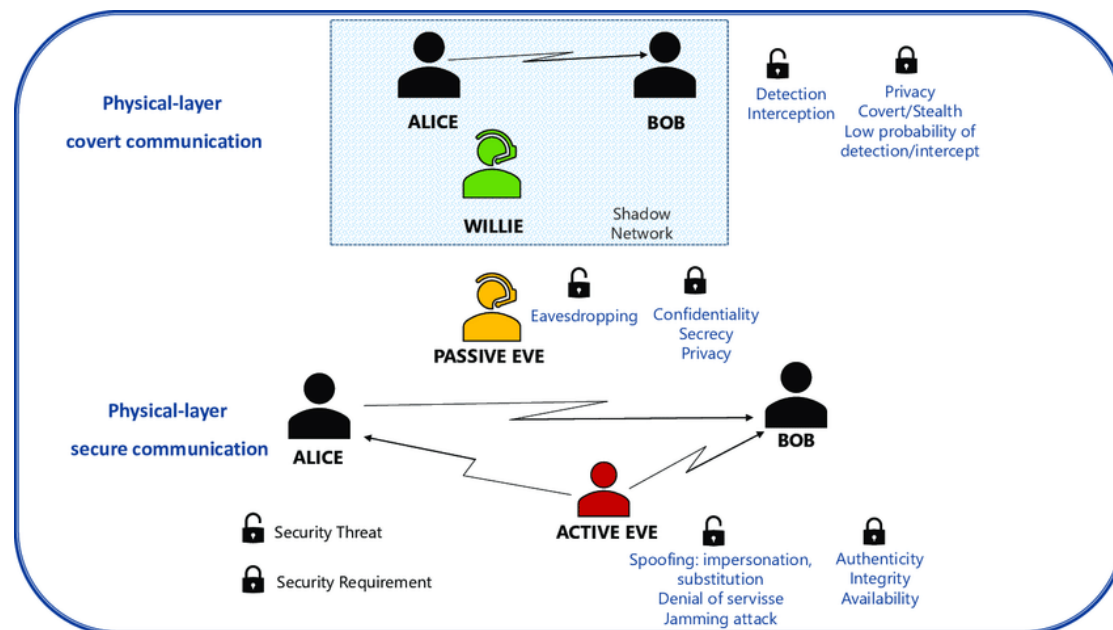
- **Desafíos (punto de partida)**
 - Cualquiera dentro del radio de acción del punto de acceso puede ser un atacante
 - Las acreditaciones del usuario se deben poder intercambiar con seguridad
 - Se debe mantener una conexión correcta en todo momento
 - Los datos se deben poder transmitir con seguridad



Wi-Fi

• Peligros

- Denegación de servicio (DoS)
- Robo de Información y/o credenciales
- Inserción de Códigos Dañinos
- Daño de Equipos
- Uso de Internet
- Otros a raíz de accesos no autorizados



Wi-Fi

- **Filtrado de direcciones MAC**

- Crear en cada PA una base de datos de direcciones MAC de los equipos que pueden acceder

- **Desventajas**

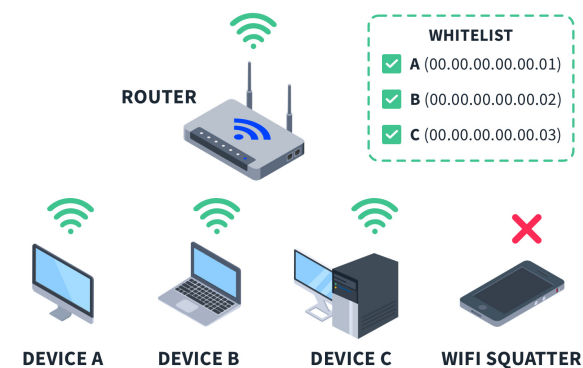
- Se debe repetir en todos los PAs existentes (puede suponer mucho trabajo y originarse errores)
- Esta medida no sirve si la dirección MAC es capturada por un atacante
- Si algún usuario pierde o le roban su máquina, queda comprometida la seguridad

MAC Address Filter List

Enter MAC Address in this format: xx:xx:xx:xx:xx:xx

➔ Wireless Client MAC List

MAC 01:		MAC 11:	
MAC 02:		MAC 12:	
MAC 03:		MAC 13:	

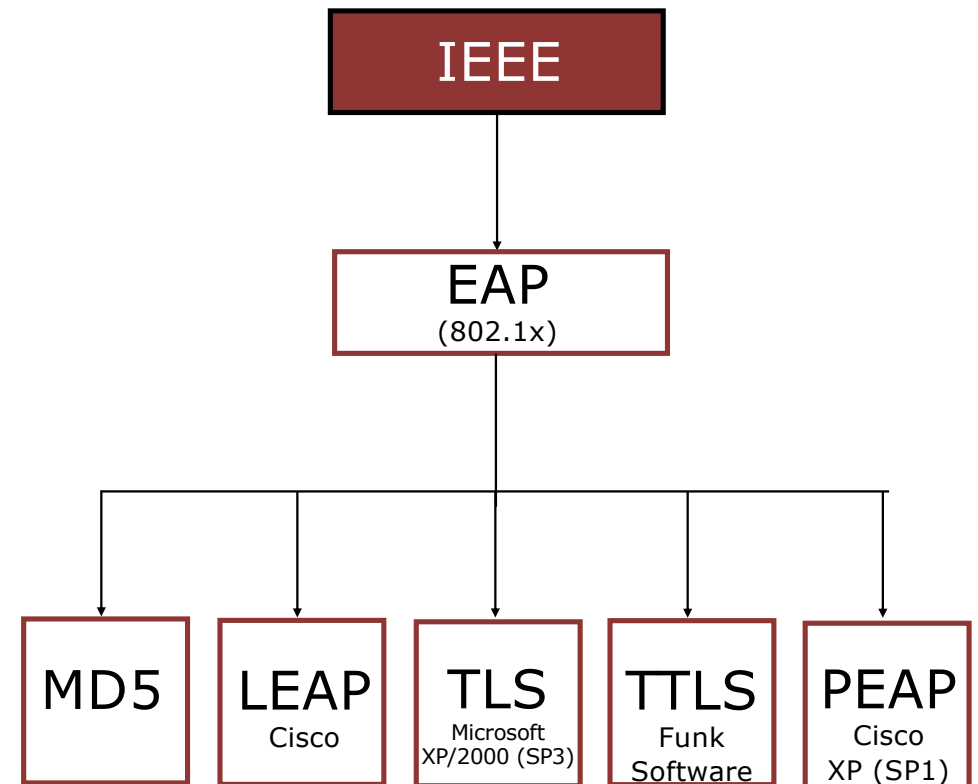


Wi-Fi

- Protocolos de Seguridad

WECA

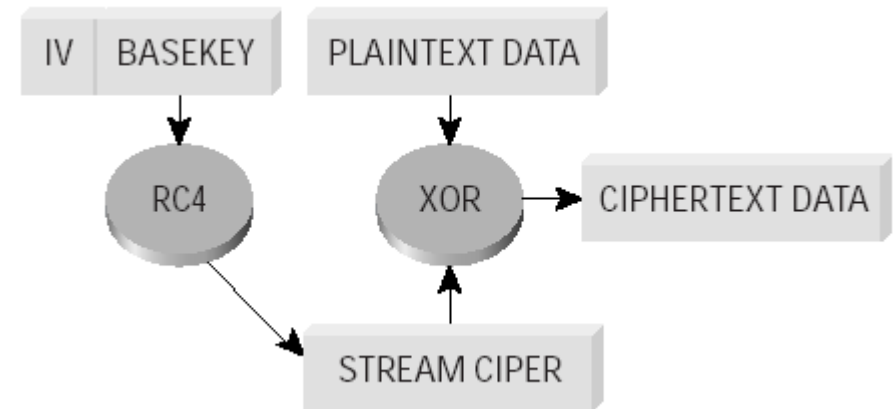
	WEP	WPA	WPA2	WPA3
Release Year	1997	2003	2004	2018
Encryption	RC4	TKIP / RC4	AES-CCMP	AES-CCMP / AES-GCMP
Session Key	64/128 bit	128 bit	128 bit	128/256 bit
Authentication	Open system, shared key	Pre-shared key	Pre-shared key	AES-CCMP / AES-GCMP
Level of Security	Very low	Low	Moderate	High
Weakness	Insecure encryption easily exploited by hackers	Weak encryption, compatibility issues	Vulnerable to key reinstallation attack (KRACK)	Complex deployment



Wi-Fi

- **WEP**

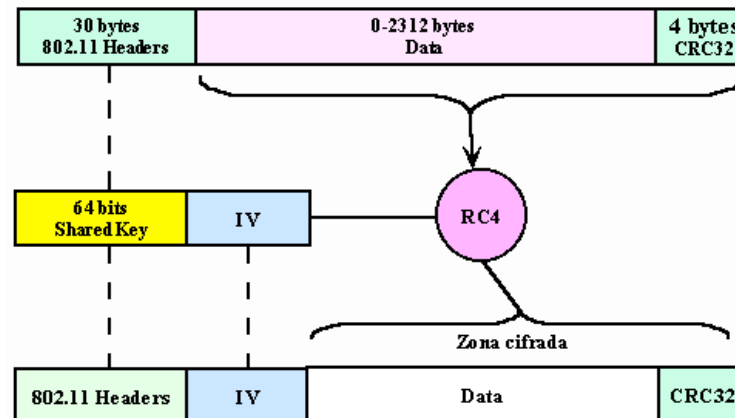
- Wired Equivalent Privacy
- Sistema de encriptación estándar 802.11
 - Se implementa en la capa MAC
 - Usa clave de tráfico RC4
 - Mecanismo:
 1. Se concatena la clave simétrica compartida (40 ó 104 bits) de la estación con un vector de inicialización aleatorio (IV) de 24 bits
 - La estructura resultante se denomina seed
 2. Se usa seed para generar un número pseudo-aleatorio, de longitud igual al payload (datos + CRC), y un valor (32 bits) para comprobar la integridad (ICV)
 3. Este número y el ICV, junto con el payload (datos + CRC), se combinan a través de un proceso XOR que producirá el texto cifrado
 4. La trama enviada incluye:
 - El texto cifrado
 - El IV e ICV sin cifrar



Wi-Fi

• WEP

- Longitud del vector IV (24 bits) es insuficiente
- El IV se repetirá cada cierto tiempo de transmisión continua para paquetes distintos, pudiendo averiguar la llave compartida
 - La captura de IVs es la base del ataque a una clave WEP
 - 2000 IVs suelen bastar para adivinar una clave
- Utilización de claves estáticas, el cambio de clave se debe realizar manualmente

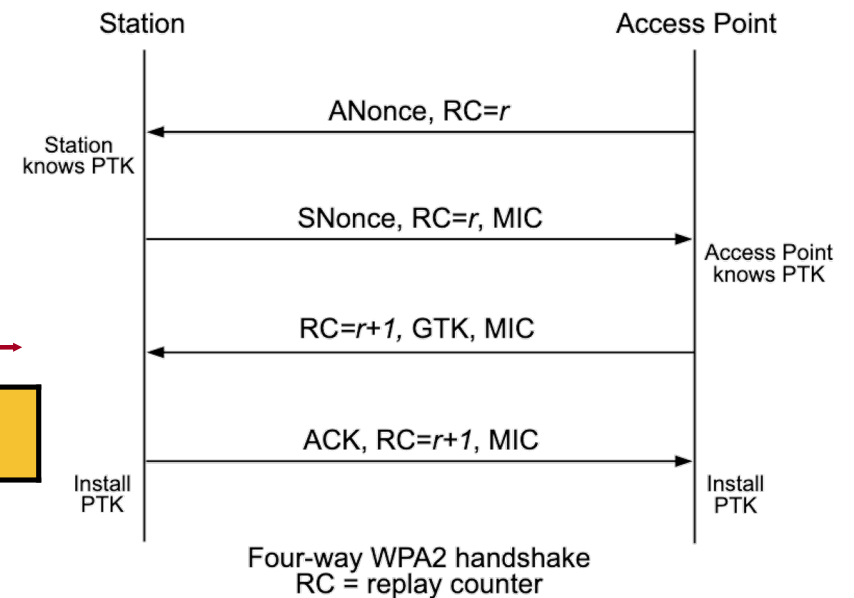
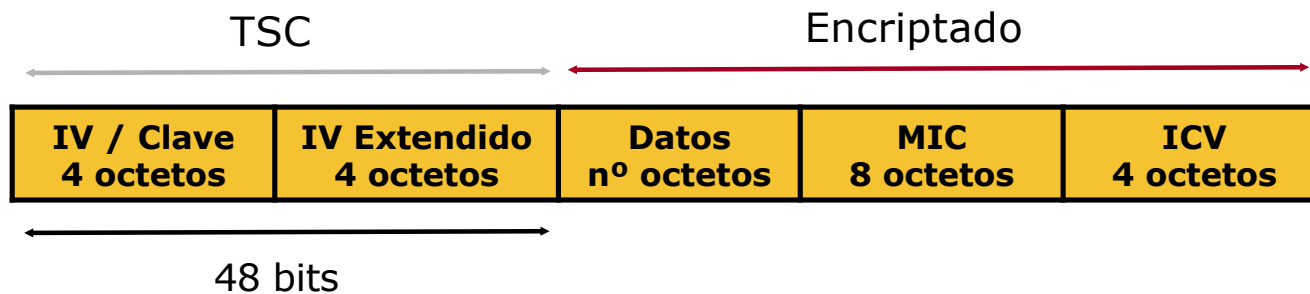




Wi-Fi

• WPA

- Wifi Protected Access
- Más fuerte que WEP y mejorada en siguientes versiones
- Autenticación de usuarios
- Temporal Key Integrity Protocol (TKIP)
 - IV de 48 bits llamado TSC (TKIP Sequence counter)
 - MIC (Integrity Check de Mensajes)
 - Encripta checksum con direcciones MAC y los datos

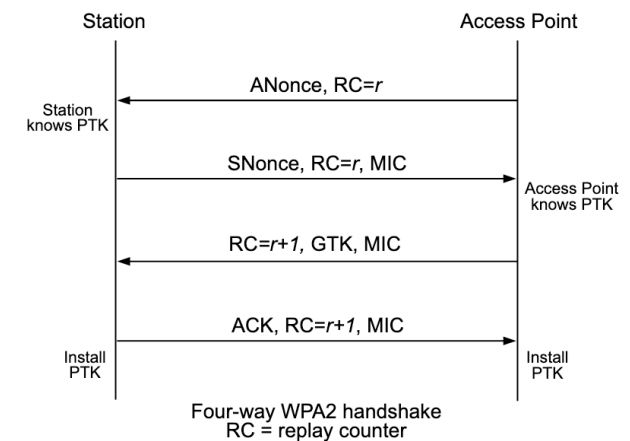
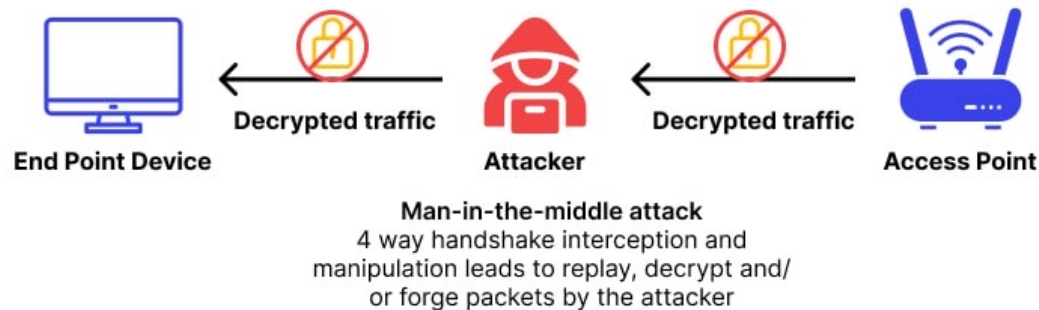


Wi-Fi

• WPA

• Key reinstallation attacks (KRACKs)

- Afecta a WPA2
- El atacante intercepta y reenvía varias veces el mensaje 3 (previo a la instalación de PTK)
- Reseteo de Nonce provoca uso de la clave de cifrado sobre diferentes valores que acaban repitiéndose
- Tramas con contenidos conocidos (predecibles) permiten la obtención de la clave
- Efecto catastrófico si víctima usa WPA-TKIP o GCMP, en vez de AES-CCMP



Wi-Fi

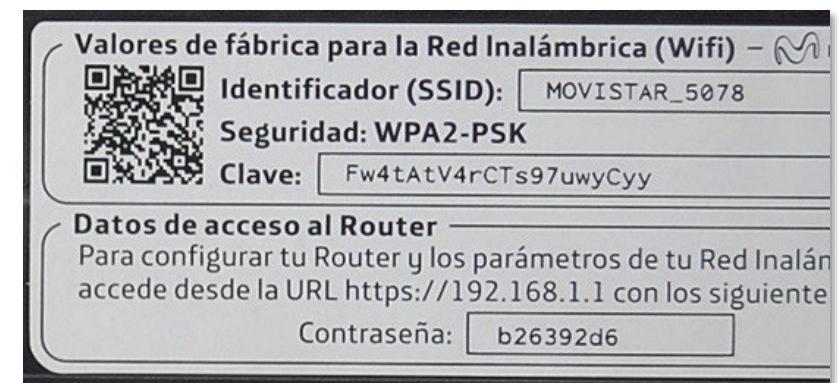
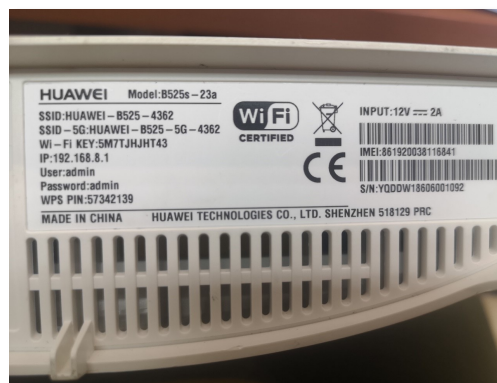
• Wi-Fi Protected Setup (WPS)

- Estándar que permite el establecimiento sencillo de conexiones seguras inalámbricas en redes domésticas
- Distintos métodos:
 - Introducción de un número PIN por parte del cliente
 - El usuario pulsa simultáneamente un botón en el PA y el cliente
 - Acercar el cliente al PA
 - Dispositivo USB
- Stefan Viehböck detecta un agujero en el diseño e implementación del WPS basado en número PIN
 - **SOLUCIÓN:** deshabilitar WPS o inhabilitar PA



Wi-Fi

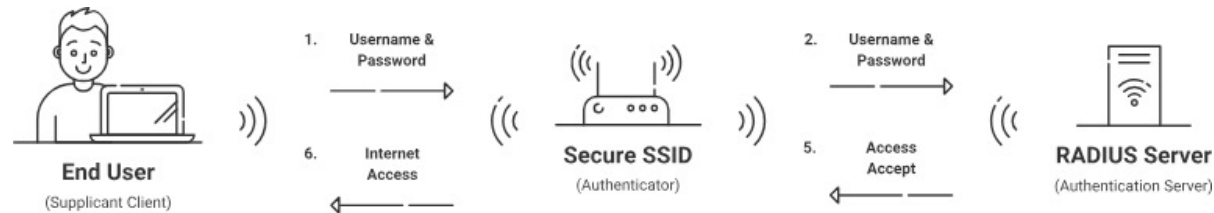
- **Riesgo: configuraciones por defecto**
 - ISPs ofrecen routers Wi-Fi configurados por defecto
 - SSID
 - Clave
 - Contraseña del router
 - Existen listas de claves asociadas al SSID y la dirección MAC del punto de acceso
 - Se debe anteponer la seguridad ante la accesibilidad



Wi-Fi

• 802.1x

- Provee método para la autenticación y autorización de conexiones a una red inalámbrica
- Autenticación basada en usuario
 - Contraseñas
 - Certificados
- Aprovechamiento de protocolos AAA (Authentication, Authorization and Accounting) tales como RADIUS
- Uso de EAP (Extensible Authentication Protocol) entre la estación móvil y el punto de acceso
 - Protege las credenciales y seguridad de los datos
 - EAP-TLS, EAP-TTLS, EAP-MD5, EAP-Cisco Wireless (LEAP), EAP-PEAP



Wi-Fi

- **802.1x**
 - **RADIUS (RFC 2058)**
 - La autenticación se basa en el usuario, en vez de basarse en el dispositivo
 - Elimina la necesidad de almacenar información de los usuarios en cada PA de la red
 - Más fácil de administrar y configurar
 - Elementos:
 - Network Access Server (NAS)
 - Cliente RADIUS
 - Diversos protocolos de autenticación (PAP, CHAP, ...)
 - SSID: UCM

Red Inalámbrica UCM



Introduzca sus credenciales para acceder a la red inalámbrica

Usuario:

Contraseña:

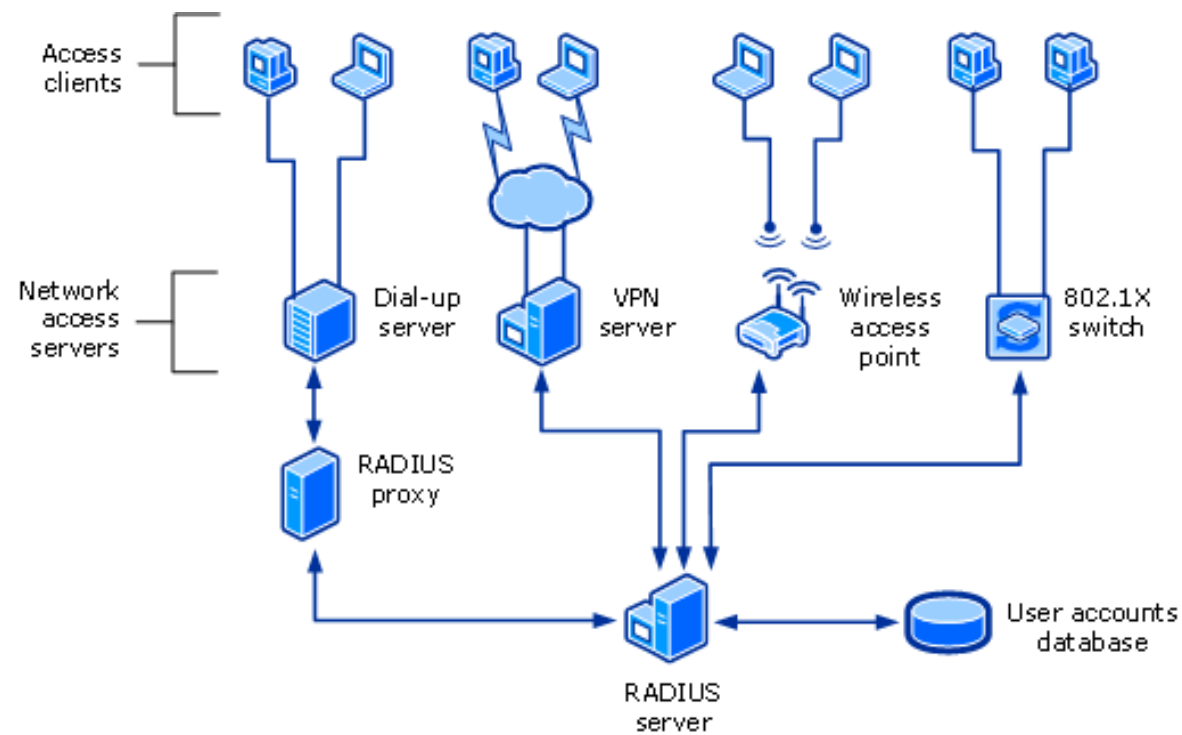
IMPORTANTE: Esta red inalámbrica no está protegida mediante cifrado por lo que se recomienda usar protocolos seguros (https y SSH), o establecer una VPN, en las conexiones que impliquen la transferencia de datos sensibles.

Los usuarios de esta red están sujetos a la siguiente normativa:

- Normas generales de utilización de la red (Consejo de gobierno UCM, 30 de enero de 2003).
- Las políticas de uso y seguridad de la Red Telemática de Investigación de Madrid y Políticas de Uso de RedIRIS.

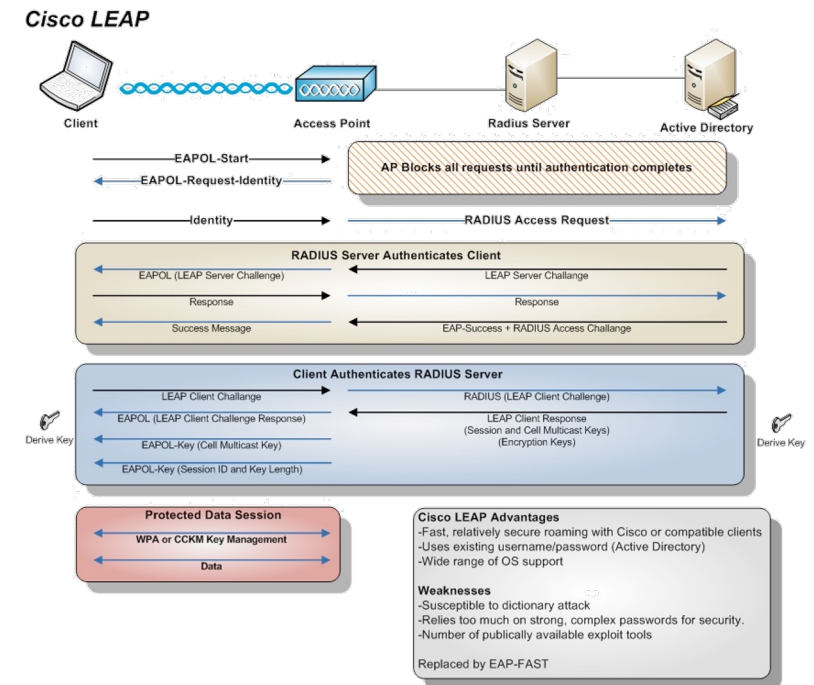
Wi-Fi

- **802.1x**
 - **RADIUS (RFC 2058)**



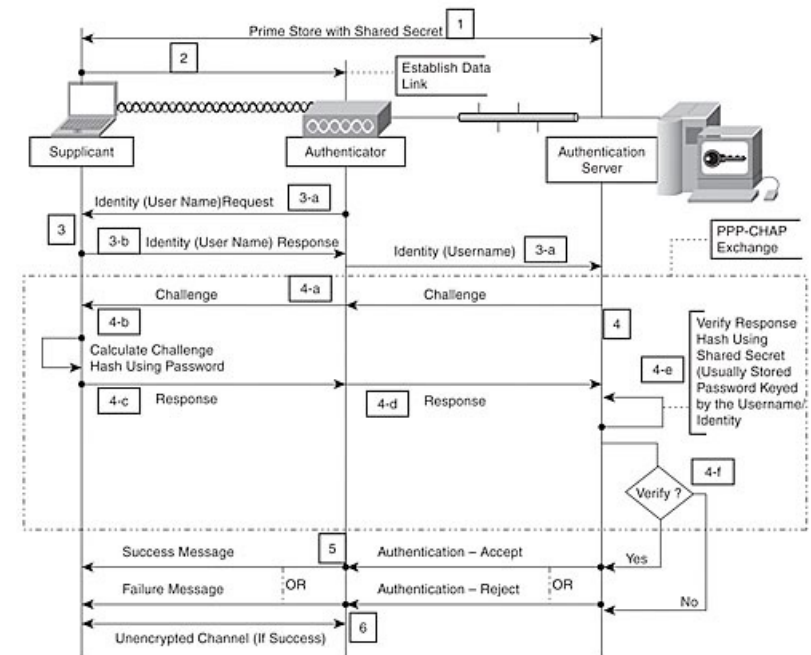
Wi-Fi

- **802.1x**
 - **LEAP (EAP Cisco Wireless)**
 - Patentado por Cisco (basado en 802.1x)
 - Multiplataforma
 - Basado en nombre de usuario y contraseña
 - Nombre de usuario se envía sin protección
 - Contraseña se envía sin protección (sujeto a ataques de diccionario)
 - No soporta One Time Password (OTP)
 - Requiere RADIUS Server con capacidad LEAP
 - Requiere Infraestructura Cisco Wireless



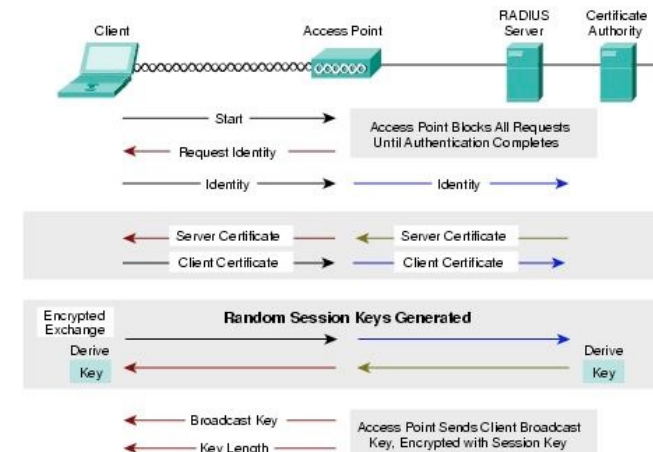
Wi-Fi

- **802.1x**
 - **EAP-MD5**
 - Basado en nombre de usuario y contraseña
 - Nombre de usuario se envía sin protección
 - Contraseña se envía sin protección (sujeto a ataques de diccionario)
 - EAP-MD5 requiere una clave fija manual WEP y no ofrece distribución automática de llaves
 - Sujeto a ataques man-in-the-middle. Sólo autentica el cliente frente al servidor, no el servidor frente al cliente



Wi-Fi

- **802.1x**
 - **EAP-TLS**
 - Patentado por Microsoft
 - Ofrece fuerte autenticación mutua, credenciales de seguridad y claves dinámicas
 - Intercambio de identidades desprotegido
 - Requiere la distribución de certificados digitales a todos los usuarios así como a los servidores RADIUS
 - Requiere una infraestructura de gestión de certificados (PKI)
 - Windows XP contiene un cliente EAP-TLS, pero obliga a los administradores a emplear sólo certificados Microsoft



Wi-Fi



- **802.1x**
 - **EAP-TTLS (Funk Software y Certicom)**
 - Permite a los usuarios autenticarse mediante nombre de usuario y contraseña, sin pérdida de seguridad
 - Ofrece fuerte autenticación mutua, credenciales de seguridad y claves dinámicas
 - Requiere que los certificados sean distribuidos sólo a los servidores RADIUS, no a los usuarios
 - No requiere certificados en clientes
 - Compatible con las actuales bases de datos de seguridad de usuarios, incluidas Windows Active Directory, sistemas token, SQL, LDAP, etc.
 - Soporta CHAP, PAP, MS-CHAP y MS-CHAPv2
 - Más sencillo de instalar

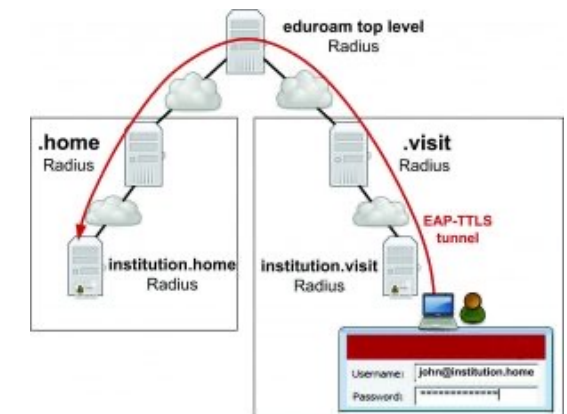
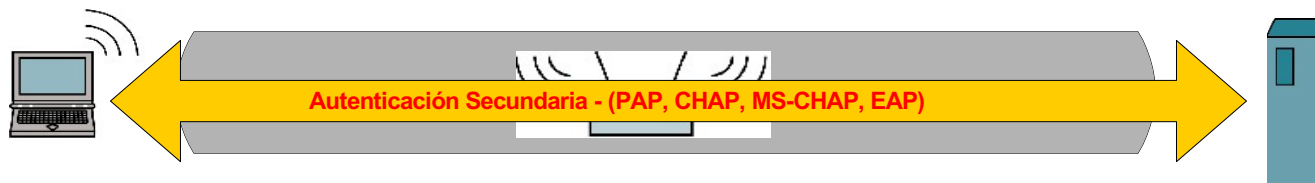
Wi-Fi

- 802.1x
 - EAP-TTLS

Fase 1 – Establecimiento de TLS



Fase 2 – Autenticación Secundaria





Wi-Fi

- 802.1x

802.1X EAP Types Feature / Benefit	MD5 --- Message Digest 5	TLS --- Transport Level Security	TTLS --- Tunneled Transport Level Security	PEAP --- Protected Transport Level Security	FAST --- Flexible Authentication via Secure Tunneling	LEAP --- Lightweight Extensible Authentication Protocol
Client-side certificate required	no	yes	no	no	no (PAC)	no
Server-side certificate required	no	yes	yes	yes	no (PAC)	no
WEP key management	no	yes	yes	yes	yes	yes
Rogue AP detection	no	no	no	no	yes	yes
Provider	MS	MS	Funk	MS	Cisco	Cisco
Authentication Attributes	One way	Mutual	Mutual	Mutual	Mutual	Mutual
Deployment Difficulty	Easy	Difficult (because of client certificate deployment)	Moderate	Moderate	Moderate	Moderate
Wi-Fi Security	Poor	Very High	High	High	High	High when strong passwords are used.

Wi-Fi

- **“Descubrimiento y revelación de secretos”**
 - Delito tipificado por código penal
 - Romper claves Wi-Fi
 - Escuchar tráfico de redes abiertas
 - **Penas:**
 - Cárcel: 1 a 4 años
 - Multas: 12 a 24 meses

